

LOGMERRY · AUTOMATISATION & IA POUR LES ENTREPRISES

# Livrables de soutenance

Mini CRM et cockpit d'activité avec assistant IA connecté à mes notes, conçu et déployé en no-code et IA.

SOUTENANCE · 16 NOVEMBRE 2026


AUTEUR
ALEX PERICAT



VERSION
5 NOVEMBRE 2026

FORMATION
BACHELOR CHEF DE PROJET NO-CODE ET IA

# Sommaire

Treize livrables, un chapitre chacun. Les mentions « À confirmer » signalent ce qui n'est pas vérifié.


01 Schéma de données 5

- Vue d'ensemble 5
- Modèle conceptuel (MCD) 6
- Dictionnaire de données 8
- Règles d'intégrité transversales 11
- Évolution du schéma 11

02 Workflows : saisie des documents et gestion de l'IA (RAG) 12

- Les trois workflows 12
- A. Saisie et indexation d'une note 13
- B. Question à l'assistant 15
- C. Propositions de l'IA 16
- Événements qui déclenchent un traitement 16
- Délais et niveaux de service (SLA) 17
- MCP : ce qu'il en est 17
- Limites et suite 18

03 UX, maquettes et système de design 19

- Principes 19
- Architecture de l'information 20
- Parcours clés 20
- Système de design 21
- Accessibilité 22
- Adaptation aux écrans 24
- Aperçu de l'application réelle 24
- Maquettes 26
- Points ouverts de la conception 27

04 Intégration : API Supabase et authentification 28

- Vue d'ensemble des échanges 28
- Les trois formes d'appel 29
- Authentification 31
- Contrat de sécurité de l'intégration 32
- Délais, erreurs et reprises 32
- Ce qui n'existe pas 33
- Limites et suite 33

05 Qualité de service 34

Comment lire les chiffres 34
Délais mesurés 34
Plafonds et délais réglés dans le code 35
Objectifs proposés 36
Contrôles automatiques à chaque envoi 36
Observabilité : ce qui existe 36
Ce qui n'existe pas 37
Modes dégradés 38
Limites et suite 38

06 Démonstration de l'application 39

Où et comment 39
Ce que la production contient (et ne contient pas) 40
Avant de commencer : la liste de contrôle 40
Scénario 41
Ce qui peut mal tourner, et la réponse 42
Ce qui n'est pas démontrable aujourd'hui 42
Limites de ce chapitre 43

07 Rapport d'évaluation de l'assistant 44

Ce qui est évalué 44
Méthode 44
Résultats de qualité 45
Pertinence et hallucinations 45
Latence 46
Coût 46
Limites de cette évaluation 47
Reproduire la mesure 47

08 Registre des données et index RAG, gouvernance 48

Registre des données du RAG 48
L'index vectoriel 49
Cycle de vie d'une note dans l'index 50
Qui reçoit quoi : les flux vers des tiers 51
Gouvernance 51
Limites et suite 52

09 Garde-fous et conformité 53

Vue d'ensemble : trois lignes de défense 53
1. Avant l'appel à l'IA 53
2. Pendant l'appel 54
3. Après l'appel : vérification avant affichage 54
Ce que les tests prouvent 55

Données personnelles 55
Garde-fous de l'application hors IA 56
Manques et risques connus 56

10 Déploiement et retour arrière 58

De mon poste à la production 58
Ce que la CI contrôle 59
Configuration de production 60
Compte rendu de mise en production (état au 5 novembre 2026) 60
Retour arrière 61
Ce qui n'existe pas 62
Limites et suite 62

11 Sécurité d'accès : authentification, droits et secrets 63

Authentification 63
Matrice des droits 64
Comment c'est garanti dans la base 65
Tests qui le prouvent 65
Secrets 66
En-têtes de sécurité du site 66
Limites et suite 67

12 Continuité de service et reprise 68

Ce que l'offre gratuite garantit, et ne garantit pas 68
Objectifs de reprise, tels qu'ils sont aujourd'hui 68
Reconstruire LogMerry de zéro 69
Exporter les données 70
Modes dégradés dans le code 70
Disponibilité et retour arrière 70
Scénarios et réponses 71
Ce qui reste à faire 71

# Schéma de données



> *Ce que ce chapitre montre.* Le modèle de données de LogMerry : 22 tables dans le schéma `public`, toutes protégées par la sécurité par ligne (RLS). Il a été relu directement dans la base Supabase du projet le 4 novembre 2026, et non reconstitué de mémoire.

01.1

## Vue d'ensemble

LogMerry sépare trois mondes, qui ne se mélangent jamais.

- **Mes données de travail** : notes, clients, missions, factures, échéances. Chaque ligne appartient à un compte (`owner_id`).
- **L'assistant IA** : les extraits de mes notes, transformés en vecteurs, et l'historique des échanges avec leurs sources.
- **Ce qui est public** : les réalisations publiées avec l'accord du client et le formulaire de contact. Le public n'a accès à aucune table : seulement à deux vues en lecture et à une fonction.

Toutes les tables pointent vers `auth.users`, la table des comptes gérée par Supabase Auth. C'est ce lien qui rend possible l'isolation entre comptes.

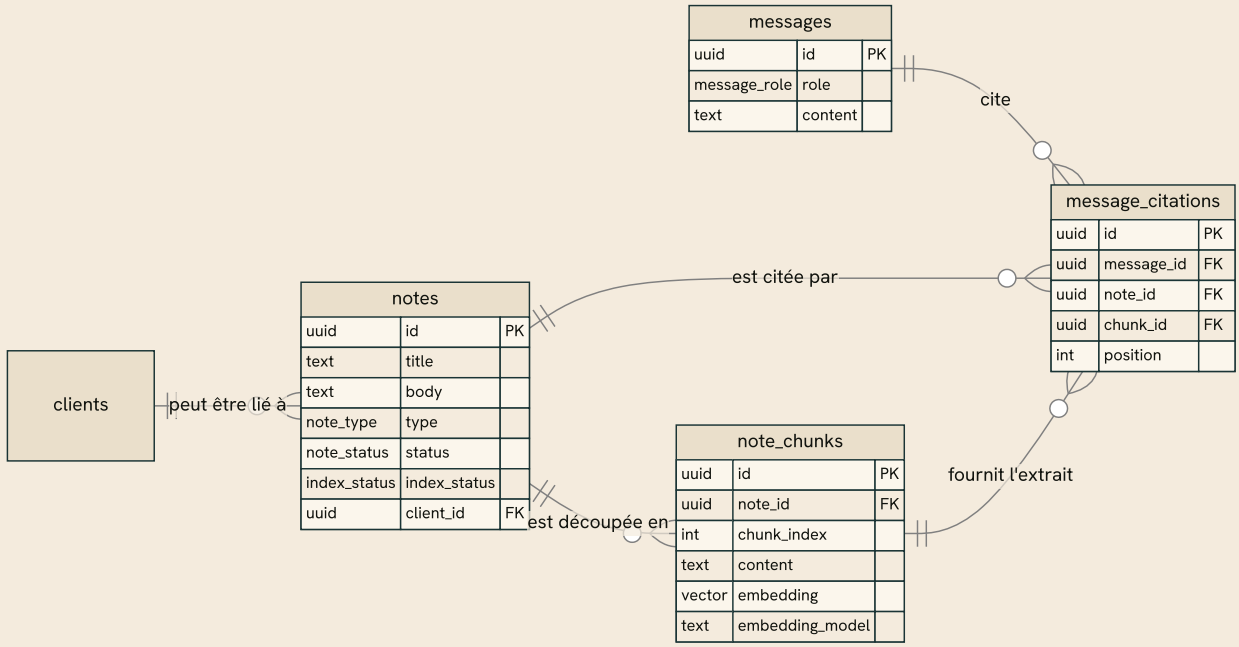
| DOMAINE | TABLES | RÔLE |
|---|---|---|
| **Connaissances et assistant** | `notes`, `note_chunks`, `messages`, `message_citations` | Base de connaissances interrogeable par l'IA, historique et citations |
| **Clients et missions agiles** | `clients`, `contacts`, `missions`, `sprints`, `user_stories`, `tasks` | CRM léger et pilotage des missions en agile |
| **Finances et échéances** | `quotes`, `invoices`, `payments`, `deadlines`, `task_checks`, `regulatory_rules`, `professional_profile` | Suivi des devis, factures, encaissements, obligations administratives |
| **Portfolio, contact, technique** | `realisations`, `realisation_images`, `contact_form_settings`, `contact_submissions`, `ai_calls` | Vitrine publique, formulaire de contact, quota d'appels à l'IA |

01.2

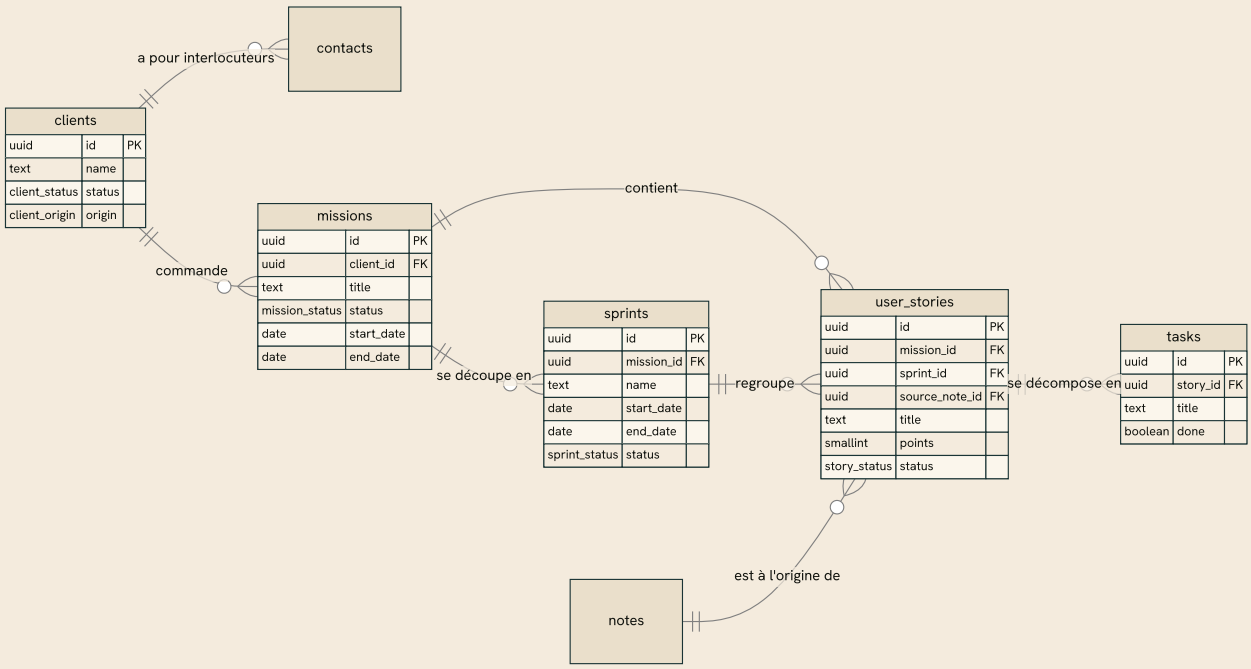
# Modèle conceptuel (MCD)

Chaque diagramme montre les liens entre les tables d'un domaine. Le lien vers `auth.users` (le propriétaire) existe sur toutes les tables et n'est pas redessiné à chaque fois.

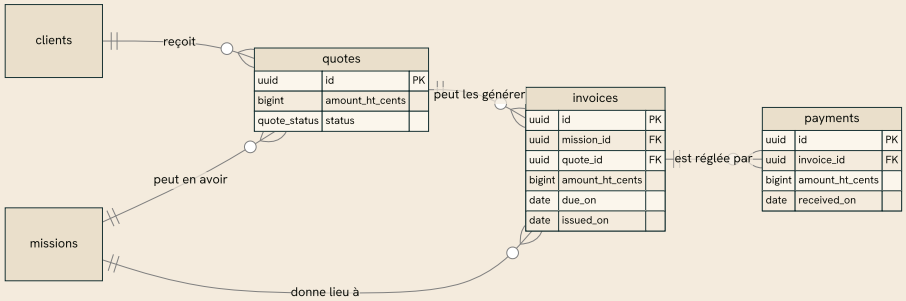
## Connaissances et assistant

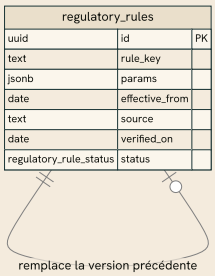


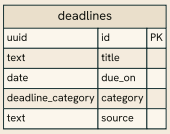

## Clients et missions agiles

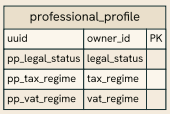


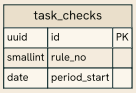
## Finances et échéances

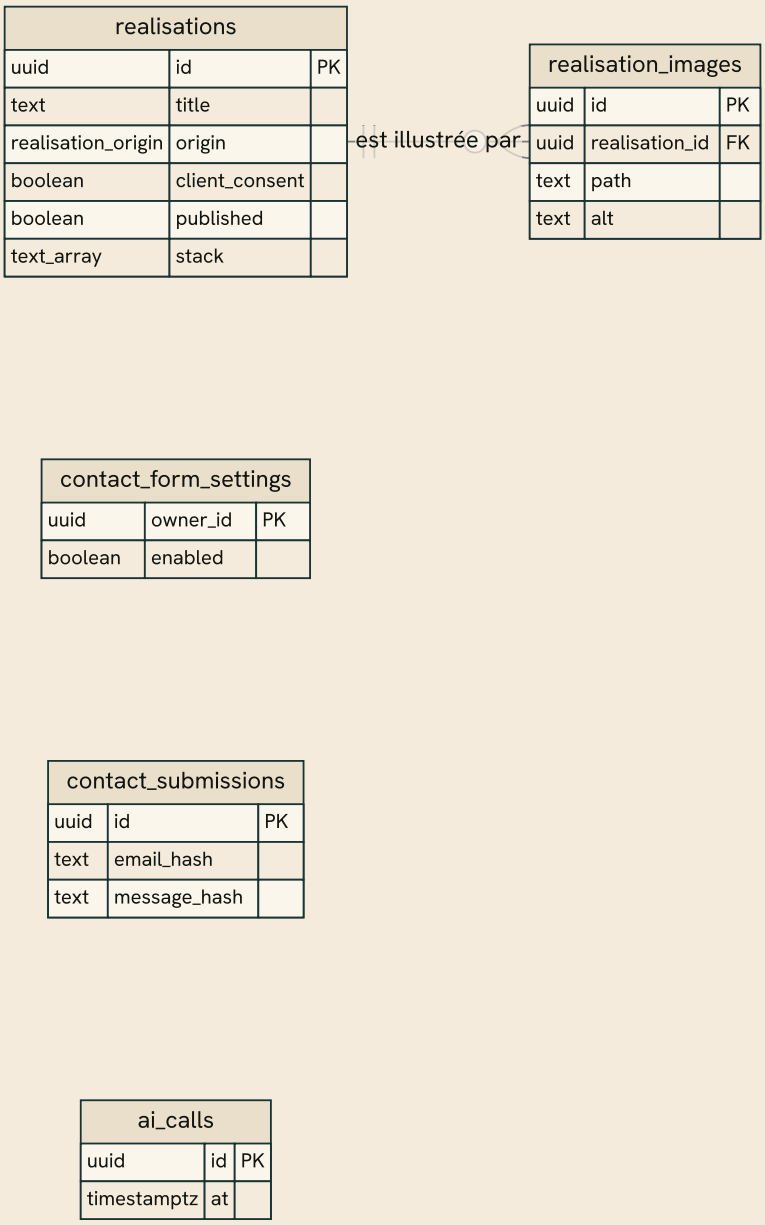





01.3

# Dictionnaire de données

Les colonnes communes ne sont pas répétées : `id` (identifiant unique généré), `owner_id` (propriétaire, valeur par défaut `auth.uid()`), `created_at` et `updated_at`.

### Connaissances et assistant

| TABLE | RÔLE | COLONNES PRINCIPALES | RÈGLES D'INTÉGRITÉ |
|---|---|---|---|
| `notes` | Une note de la base de connaissances | `title`, `body`, `type` (note, procédure, modèle, FAQ), `status` (brouillon, active), `index_status` (en attente, indexée, échec), `client_id` (facultatif), `search` (index plein texte français généré) | Titre de 1 à 200 caractères, texte de 50 000 caractères au plus ; le client lié doit appartenir au même propriétaire |
| `note_chunks` | Un extrait d'une note, avec son vecteur | `note_id`, `chunk_index`, `content`, `embedding` (vecteur), `embedding_model` | Index positif, contenu non vide, modèle d'embeddings obligatoire |
| `messages` | Un message de l'historique du chat | `role` (utilisateur, assistant), `content` | De 1 à 20 000 caractères |
| `message_citations` | Les sources d'une réponse | `message_id`, `note_id`, `chunk_id`, `position` | Position positive ; supprimée avec son message ; si la note ou l'extrait cité disparaît, la citation reste, avec un lien vide |

### Clients et missions agiles

| TABLE | RÔLE | COLONNES PRINCIPALES | RÈGLES D'INTÉGRITÉ |
|---|---|---|---|
| `clients` | Un prospect ou un client | `name`, `status` (prospect, client), `origin` (client réel, formation, ami, démo) | Nom de 1 à 200 caractères |
| `contacts` | Un interlocuteur chez un client | `client_id`, `name`, `job_title`, `email`, `phone`, `address` | E-mail de 254 caractères au plus avec une arobase entourée de texte ; téléphone 30 caractères au plus ; adresse 500 au plus |
| `missions` | Une mission pour un client | `client_id`, `title`, `status` (prévue, en cours, terminée, annulée), `start_date`, `end_date` | Titre de 1 à 200 caractères |
| `sprints` | Un sprint d'une mission | `mission_id`, `name`, `goal`, `start_date`, `end_date`, `status` | Nom de 1 à 120 caractères ; un seul sprint actif par mission (index unique partiel) |
| `user_stories` | Une user story du backlog | `mission_id`, `sprint_id`, `source_note_id`, `title`, `role`, `benefit`, `acceptance_criteria`, `points`, `status`, `position` | Points limités à 1, 2, 3, 5, 8 ou 13 ; critères de 4 000 caractères au plus |
| `tasks` | Une tâche d'une story | `story_id`, `title`, `done`, `done_at`, `position` | Titre de 1 à 200 caractères |

### Finances et échéances

| TABLE | RÔLE | COLONNES PRINCIPALES | RÈGLES D'INTÉGRITÉ |
|---|---|---|---|
| `quotes` | Un devis | `client_id`, `mission_id`, `amount_ht_cents`, `tax_cents`, `status` (brouillon, envoyé, accepté, refusé) | Montants en centimes : strictement positif pour le montant, positif ou nul pour la taxe |
| `invoices` | Une facture de suivi | `mission_id`, `quote_id`, `amount_ht_cents`, `tax_cents`, `due_on`, `issued_on`, `reference` | Montant de 1 centime à 1 000 000 euros ; référence de 60 caractères au plus |
| `payments` | Un encaissement | `invoice_id`, `amount_ht_cents`, `tax_cents`, `received_on` | Mêmes bornes de montant que les factures |
| `deadlines` | Une échéance administrative | `title`, `due_on`, `category`, `priority`, `recurrence`, `series_id`, `series_day`, `source` | La source est une adresse en `https://` ; jour de série de 1 à 31 |
| `regulatory_rules` | Une règle réglementaire versionnée | `rule_key`, `activity_category`, `params` (JSON), `effective_from`, `effective_to`, `source`, `verified_on`, `revalidate_after`, `status` | Source obligatoire ; statut : à vérifier, vérifiée, essai ; une version peut pointer vers la précédente |
| `professional_profile` | Le profil professionnel (une ligne par compte) | Statut juridique, régime fiscal, TVA, ACRE, fréquence URSSAF, etc., chacun avec sa date de confirmation | Une donnée inconnue reste vide : jamais préremplie ; seuils d'alerte validés par une fonction |
| `task_checks` | Les contrôles du cockpit déjà faits | `rule_no`, `source_id`, `period_start`, `ceiling_key`, `threshold` | Numéro de règle de 1 à 8 ; seuil : 50, 75, 90 ou 100 |

### Portfolio public, contact et technique

| TABLE | RÔLE | COLONNES PRINCIPALES | RÈGLES D'INTÉGRITÉ |
|---|---|---|---|
| `realisations` | Une réalisation du portfolio | `title`, `description`, `origin`, `status`, `problem`, `design_choice`, `tests`, `validation`, `result_figure`, `stack`, `link_url`, `client_consent`, `published` | Champs texte de 600 caractères au plus ; adresse en `https://` ; 12 outils au plus ; visible du public seulement si publiée **et** accord du client (filtre des vues publiques) |
| `realisation_images` | Une capture d'une réalisation | `realisation_id`, `path`, `alt` | Chemin au format imposé (dossier du propriétaire), unique ; texte alternatif obligatoire |
| `contact_form_settings` | Qui reçoit les messages du formulaire | `owner_id`, `enabled` | Un seul destinataire activé à la fois (index unique partiel) |

| TABLE | RÔLE | COLONNES PRINCIPALES | RÈGLES D'INTÉGRITÉ |
|---|---|---|---|
| `contact_submissions` | Journal des envois du formulaire | `email_hash`, `message_hash` | Aucun texte de message : des empreintes seulement ; lignes de plus de 30 jours supprimées |
| `ai_calls` | Un appel à l'IA, pour le quota | `at` | Compté par une fonction (`consume_ai_quota`) |

01.4

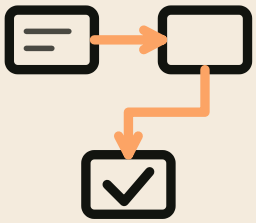
## Règles d'intégrité transversales

- **Un propriétaire sur chaque ligne.** `owner_id` vaut `auth.uid()` par défaut et pointe vers `auth.users`. La suppression d'un compte supprime en cascade toutes ses données (vérifié sur les 22 tables).
- **Sécurité par ligne partout.** Les 22 tables ont la RLS activée. Chaque politique est réservée aux comptes connectés et relie les lignes à `auth.uid()`. Aucune politique n'est ouverte à tous. Un test automatique le vérifie à chaque modification des migrations.
- **Montants en centimes entiers.** Jamais de nombre décimal pour l'argent.
- **Textes bornés.** Chaque texte a une longueur minimale et maximale, contrôlée par la base, pas seulement par l'interface.
- **Valeurs fermées.** Les statuts et les types sont des énumérations : la base refuse toute autre valeur.
- **Rien d'inventé.** Une donnée personnelle inconnue reste vide (« À confirmer »). Les règles fiscales sont dans une table versionnée, avec source et date de vérification : aucun taux ni plafond n'est écrit dans le code.
- **Le vecteur dépend du modèle.** La dimension des vecteurs est liée au modèle d'embeddings (`mistral-embed`, 1 024 dimensions). Changer de modèle impose de tout réindexer : `embedding_model` garde la trace du modèle utilisé pour chaque extrait.
- **Le public ne touche aucune table.** Il lit deux vues (`public_realisations`, `public_realisation_images`) qui filtrent « publiée **et** accord du client », et exécute une seule fonction, `submit_contact_message`.

01.5

## Évolution du schéma

Le schéma évolue par migrations versionnées, dans le dossier `supabase/migrations/` (55 fichiers, du 13 octobre au 7 novembre 2026). Après chaque migration, les types TypeScript sont régénérés, si bien qu'un schéma qui diverge du code est détecté à la compilation.



# Workflows : saisie des documents et gestion de l'IA (RAG)

> *En deux phrases.* Une note suit un chemin court : elle est *enregistrée d'abord*, puis vectorisée ; l'IA ne peut jamais empêcher l'enregistrement. Une question suit un chemin plus long, où chaque étape peut échouer sans casser le reste (refus propre, pas de réponse fausse). Aucun *MCP* n'est intégré à l'application : le MCP Supabase ne sert qu'au développement.

Faits relevés dans le code et les tests le 5 novembre 2026. Les délais annoncés sont des **délais d'attente du code** ou des **mesures** ; il n'existe aucun engagement de service (SLA) contractuel.

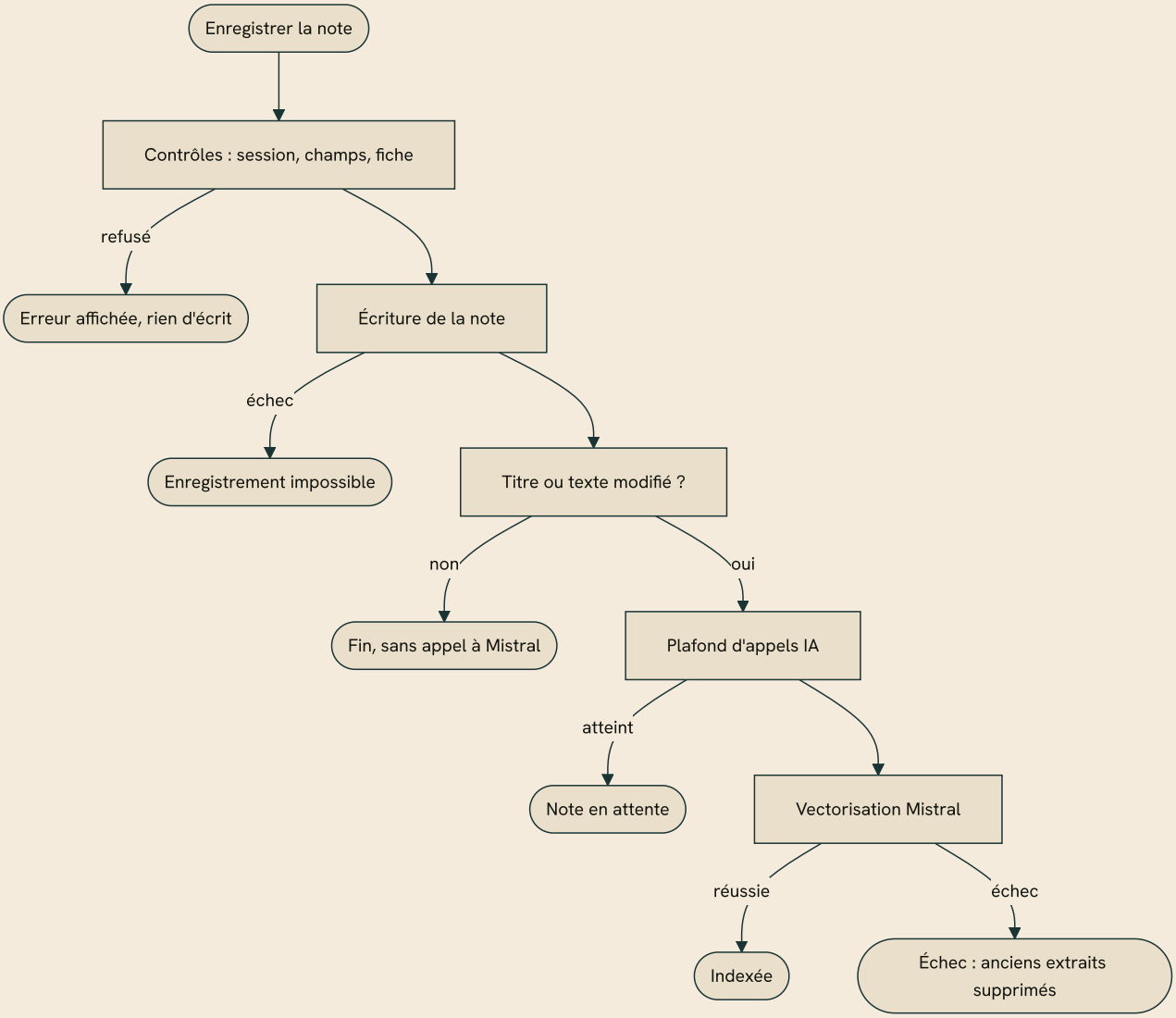
02.1

## Les trois workflows

| N° | WORKFLOW | DÉCLENCHEUR | RÉSULTAT |
|---|---|---|---|
| A | Saisie et indexation d'une note | Le propriétaire enregistre, modifie ou supprime une note | Note enregistrée, extraits vectorisés (ou état « échec » rattrapable) |
| B | Question à l'assistant | Le propriétaire pose une question | Réponse sourcée et vérifiée, ou refus clair ; échange enregistré |
| C | Propositions de l'IA (stories, tâches, ordre, sprint, prompt, résumé) | Le propriétaire demande une proposition | Proposition **éphémère**, rien d'écrit tant qu'elle n'est pas gardée |

02.2

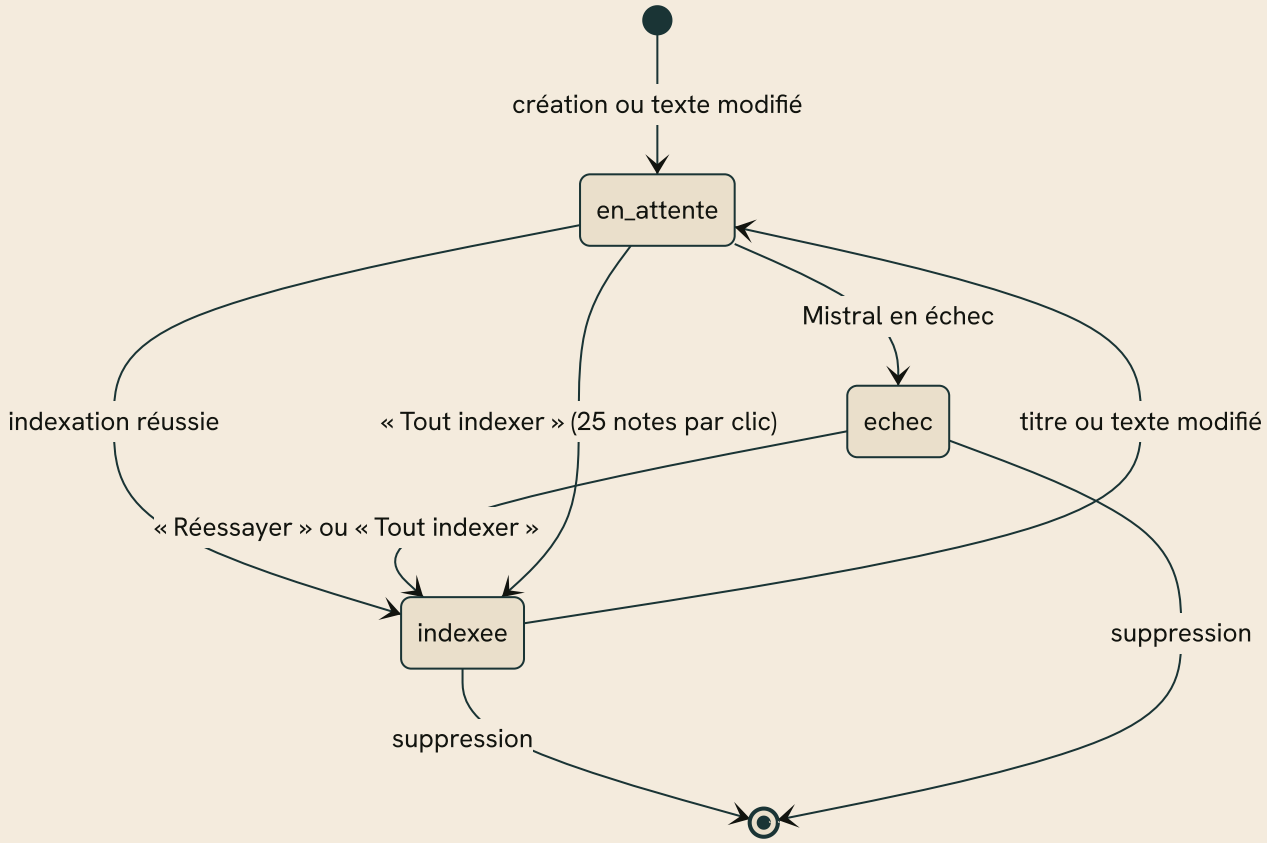
# A. Saisie et indexation d'une note




**Règles.**

- Titre obligatoire, 200 caractères au plus ; texte de 50 000 caractères au plus ; type parmi note, procédure, modèle, FAQ. La base **refuse** aussi ces limites (double contrôle).
- `owner_id` est posé par la base, jamais par l'écran.
- La fiche client liée est facultative ; on peut en créer une comme **prospect** dans le même geste (deux écritures : si la note échoue, la fiche reste, supprimable).
- Une modification qui ne touche ni le titre ni le texte d'une note déjà indexée **n'appelle pas Mistral**.
- Les vecteurs sont calculés **avant** toute écriture d'extraits ; l'échec supprime les anciens extraits plutôt que de laisser un texte périmé.
- Supprimer une note supprime ses extraits (cascade) ; les citations qui la visaient deviennent vides, les réponses restent.

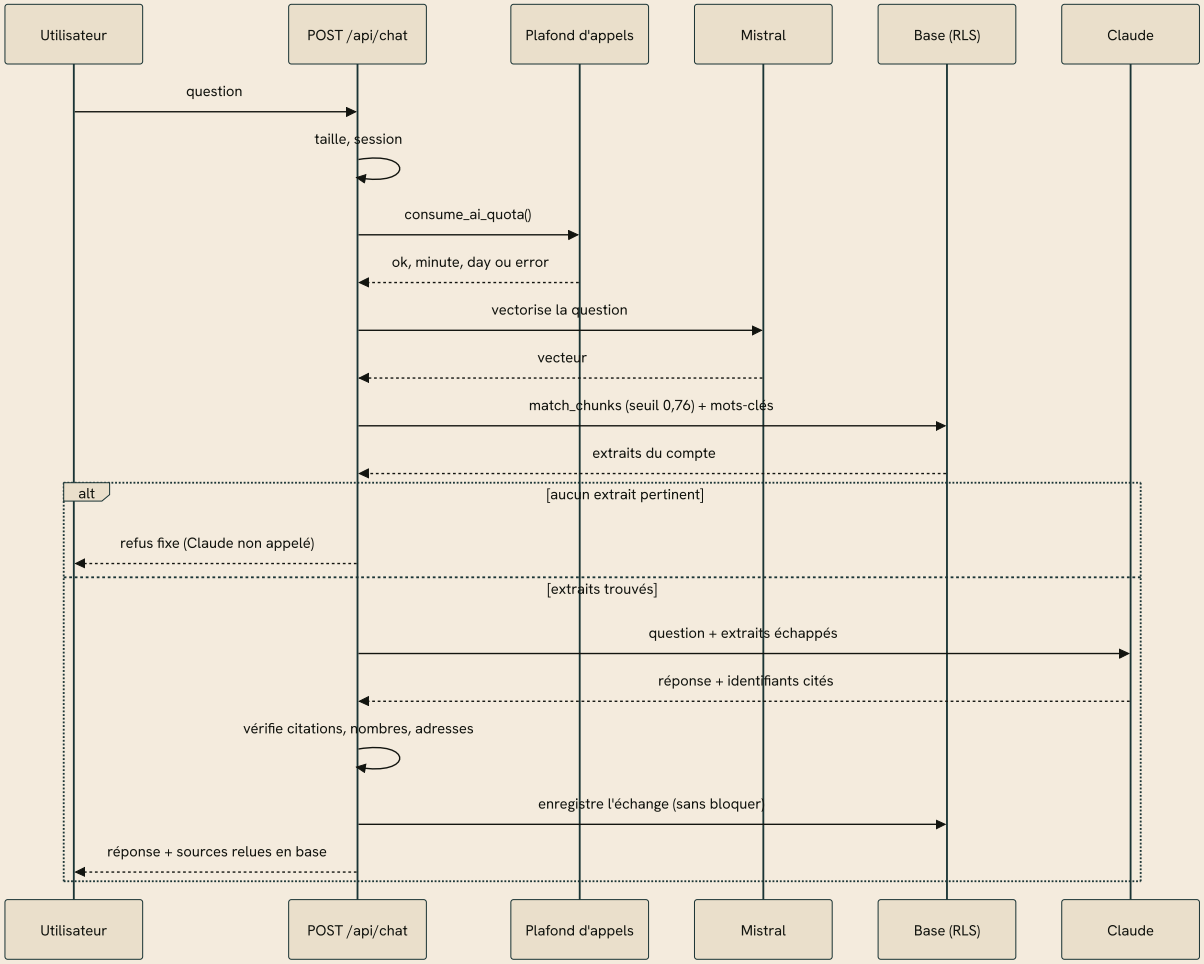
### États d'une note




Un second état existe, **indépendant** : `draft` (brouillon) ou `active`. Un brouillon naît de deux façons : le bouton « Créer une note à documenter plus tard » de l'assistant (titre « À documenter : … », texte vide, jamais citable) ou un message du formulaire de contact public. **Constat** : aucune action de l'application ne fait passer une note de `draft` à `active` (la modification ne change pas ce statut) ; les propositions agiles, qui n'utilisent que des notes `active`, ne verront donc pas un brouillon complété. **À confirmer avec Alex** : comportement voulu ou manque.

02.3

# B. Question à l'assistant




**Règles.**

- Deux voies de recherche : par le **sens** (vecteurs, seuil 0,76, 8 extraits au plus) et par **mots-clés** (5 au plus) ; les extraits trouvés par les deux sont fusionnés sans doublon.
- Sans extrait pertinent : message fixe « Je n'ai trouvé aucune procédure documentée correspondant à cette requête », **sans appel à Claude**, avec l'offre de créer une note à documenter.
- Claude ne renvoie que des **identifiants** de sources ; le texte des sources est relu en base.
- La réponse est vérifiée (citations envoyées, nombres, adresses) **avant** l'affichage ; sinon rejet.
- Une réponse sans citation s'affiche avec « Aucune de tes notes ne soutient cette réponse ».
- L'enregistrement de l'historique **ne bloque jamais** la réponse.

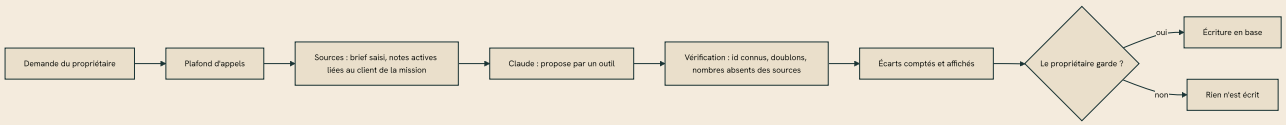
## Exceptions

| SITUATION | CE QUE VOIT L'UTILISATEUR | STATUT |
|---|---|---|
| **Pas de session (session expirée)** | « Ta session a expiré. Recharge la page pour te reconnecter. » | 401 |
| **Question vide** | « Écris une question. » | 400 |

| SITUATION | CE QUE VOIT L'UTILISATEUR | STATUT |
|---|---|---|
| **Question ou corps trop longs** | « Question trop longue. » | 413 |
| **Plafond atteint (20 par minute, 300 par jour)** | Message dédié, réessayer plus tard | 429 |
| **Compteur de plafond indisponible** | « Le compteur d'appels à l'IA est indisponible. » (on bloque plutôt que de laisser passer) | 503 |
| **Mistral ou Claude en échec ou en délai (20 s, 60 s)** | « L'assistant n'a pas pu répondre pour le moment. » | 502 |
| **Réponse rejetée par la vérification** | « La réponse n'a pas pu être vérifiée par rapport à tes notes, elle n'est pas affichée. Réessaie. » | 502 |
| **Échec de l'enregistrement de l'historique** | Rien : la réponse s'affiche ; journal sans contenu | 200 |

02.4

## C. Propositions de l'IA




Propositions : user stories (avec tâches si demandé), tâches d'une story, ordre du backlog, composition d'un sprint, relecture d'une story, prompt de mission, résumé d'une note. Règles communes : **éphémères** tant que le propriétaire ne les garde pas ; seules les notes **actives liées à la fiche du client de la mission** sont envoyées ; un chiffre absent des sources fait écarter la proposition (ou sa raison) ; texte fourni traité comme **donnée**. Détail au chapitre 9.

02.5

## Événements qui déclenchent un traitement

| ÉVÉNEMENT | TRAITEMENT | SYNCHRONE ? |
|---|---|---|
| **Note enregistrée ou modifiée** | Indexation (workflow A) | **Oui** : l'enregistrement attend la fin de l'indexation avant de rendre la main |
| **Clic sur « Réessayer » ou « Tout indexer »** | Indexation de la note, ou de 25 notes au plus par clic | Oui |
| **Question posée** | Workflow B | Oui, sans flux : la réponse arrive en une fois |

| ÉVÉNEMENT | TRAITEMENT | SYNCHRONE ? |
|---|---|---|
| **« Vider la conversation »** | Suppression de tout l'historique du compte | Oui |
| **Message du formulaire de contact** | Note en brouillon chez le destinataire (non indexée tant qu'on ne relance pas l'indexation) | Oui |

Il n'existe **aucune tâche planifiée ni file d'attente** dans l'application : tout se passe à la demande. Rappels et résumé hebdomadaire (n8n) sont hors du MVP.

02.6

## Délais et niveaux de service (SLA)

| MESURE | VALEUR | NATURE |
|---|---|---|
| **Réponse de l'assistant** | Environ 3,4 s en moyenne ; 6 à 7 s pour la plus lente des 20 questions | **Mesurée** sur deux exécutions du 4 novembre 2026 (chapitre 7) : ordre de grandeur, pas une garantie |
| **Délai maximal d'un appel à Claude** | 60 s | Réglage du code |
| **Délai maximal d'un appel à Mistral** | 20 s par lot de 16 textes | Réglage du code |
| **Plafond d'appels à l'IA** | 20 par minute, 300 par jour, par compte | Règle de la base |
| **Disponibilité de l'application** | Aucun engagement ; offre gratuite de Supabase, pause possible après une semaine d'inactivité | Voir chapitre 12 |
| **Temps d'indexation d'une note** | **À confirmer** : non mesuré (un appel Mistral, au plus 20 s) | — |

02.7

## MCP : ce qu'il en est

Aucun serveur MCP n'est intégré à LogMerry : pas de fichier `.mcp.json`, pas de dépendance, aucun appel dans le code de l'application. Le **MCP Supabase** est utilisé **uniquement pendant le développement** (migrations, types, lecture de la base, avis de sécurité), en lecture seule hors modification du schéma, avec approbation manuelle des appels. Si un MCP était un jour intégré à l'application, il faudrait décrire ici ses droits et ses flux.

02.8

# Limites et suite

| LIMITE | CONSÉQUENCE | PISTE |
|---|---|---|
| **Indexation synchrone dans l'enregistrement** | Enregistrer une note peut durer jusqu'à 20 s si Mistral est lent | Indexer en arrière-plan (file d'attente), si l'usage le justifie |
| **Pas de nouvelle tentative automatique** | Une panne brève se voit tout de suite | Une reprise unique avec attente |
| **Aucun passage de `draft` à `active`** | Un brouillon complété n'alimente pas les propositions agiles | À trancher avec Alex |
| **Pas de flux de réponse** | L'utilisateur attend la réponse complète | Flux (streaming), après le MVP |



# UX, maquettes et système de design

> *En deux phrases.* LogMerry est pensé *ordinateur d'abord*, en français, avec une barre latérale, un assistant qui s'ouvre depuis toute page et un cockpit « Aujourd'hui » pour premier écran de travail. L'interface obéit à un *système de jetons* (aucune couleur ou police écrite en dur) et à un *plancher d'accessibilité* WCAG 2.1 AA, mesuré le 29 octobre 2026 : Lighthouse accessibilité à 100 sur les cinq pages testées, avec des limites de méthode écrites plus bas.

Sources : `DESIGN.md` (aspect, statut « final », mis à jour le 18 octobre 2026), `EXPERIENCE.md` (comportement), `docs/ui-rules.md` (contrat court), `docs/audit-accessibilite.md` (audit du 29 octobre 2026), `docs/ux-resume.md`. Quand ces documents divergent, `DESIGN.md` et `EXPERIENCE.md` font foi.

03.1

## Principes

| PRINCIPE | TRADUCTION DANS L'INTERFACE |
|---|---|
| **Un cockpit, pas un tableau de bord chargé** | « Aujourd'hui » liste les tâches du jour **avec leur motif** (« facture échue depuis 1 jour ») ; cocher une tâche réordonne la liste |
| **Un assistant toujours à portée** | Panneau ouvrable depuis toute page, réponse d'abord en 2 ou 3 puces, sources dessous, « Copier le texte » et « Ouvrir » la note complète |
| **Dire quand on ne sait pas** | Refus clair de l'assistant, « paramètre manquant » plutôt qu'un chiffre douteux, « À confirmer » pour une donnée inconnue |
| **Jamais la couleur seule** | Un statut = une icône + un mot + sa couleur |
| **Aucun montant calculé sans étiquette** | Tout montant calculé porte « estimation » |
| **Sobre et net** | Grille nette, fort contraste, traits marine de 2 px et ombre dure en thème clair |

03.2

## Architecture de l'information

Barre latérale fixe à gauche (repliable en icônes), le cockpit en première entrée, assistant en panneau poussé à droite (décision confirmée par Alex).

| SURFACE | RÔLE |
|---|---|
| **Connexion, mot de passe oublié** | Accès sécurisé (pas d'inscription : voir ci-dessous) |
| **Aujourd'hui** | Tâches du jour avec motif, jauges de plafond, lignes « paramètre manquant » |
| **Assistant + historique** | Question, réponse citée, échanges conservés |
| **Notes** | Base de connaissances, recherche (mots et sens), résumé généré |
| **Clients (prospects, contacts, devis)** | CRM minimal |
| **Missions** | Backlog agile (stories, tâches, sprints), glisser-déposer, propositions de l'IA, prompt de mission |
| **Factures et encaissements** | Montants, statut « payée » déduit des encaissements |
| **Calendrier** | Échéances administratives, source unique des obligations |
| **Profil, Règles, Plafonds** | Données personnelles, règles réglementaires versionnées, jauges de plafond |
| **Réalisations** | Édition du portfolio, accord du client, publication |
| **À faire** | Éléments à documenter plus tard (notes en brouillon) |
| **Portfolio public** | Vitrine en lecture seule et formulaire de contact, sans connexion |

> *Écart entre la conception et l'application.* `EXPERIENCE.md` mentionne un écran d'inscription et une page « Finances » (estimation de cotisations). *Aucun des deux n'existe dans l'application* : il n'y a pas de page d'inscription (l'inscription est désactivée dans Supabase, chapitre II), et le dossier `app/(app)/` n'a pas de page « Finances ». La spécification est donc en avance sur le code sur ces deux points.

03.3

## Parcours clés

**1. Le cockpit du lundi matin.** Connexion, arrivée sur « Aujourd'hui », lecture des tâches et de leur motif, cochage (retour de satisfaction, la liste se réordonne), message « Bravo, tu as fait toutes tes tâches du jour. » à la dernière.

**2. Retrouver une procédure pendant une visioconférence.** Ouvrir l'assistant dans un coin de l'écran, taper des mots-clés, lire la réponse en 2 ou 3 puces, copier le texte dans le chat de la visio, ouvrir ensuite la note complète. Si rien n'est trouvé : l'assistant le dit et propose « Créer une note à documenter plus tard ».

**3. Un visiteur consulte une réalisation (personnage fictif).** Ouverture du lien reçu par e-mail ; en dix secondes, l'impression d'une personne rigoureuse et soignée ; lecture d'une réalisation (description, captures, chiffre de résultat, outils) ; message à Alex par le formulaire de contact. Le nom du client n'apparaît jamais sans son accord.

**4. Concevoir une mission en agile avec l'IA.** Backlog en une ligne par story ; propositions de stories par l'IA à partir d'un brief et de notes cochées, à garder, modifier ou rejeter ; tâches proposées une par une ; glisser-déposer à la souris, au doigt ou **au clavier** (Espace, flèches, Espace, Échap annule), chaque déplacement annoncé ; génération d'un prompt à confier à un autre assistant, avec une case « sans le nom du client ».

Le texte complet des parcours, étape par étape, est dans `EXPERIENCE.md` (section Key Flows).

03.4

# Système de design

### Jetons et règles

Le contrat tient en 13 règles (`docs/ui-rules.md`), dont :

| RÈGLE | CONTENU | CONTRÔLE AUTOMATIQUE |
|---|---|---|
| 1 | **Aucune valeur de couleur, de police ou de rayon dans un composant** : uniquement des jetons | `lib/theme.test.ts` |
| 3 | Un statut = icône + mot + couleur | Revue |
| 5 | Texte ≥ 4,5:1, éléments d'interface ≥ 3:1, en clair et en sombre | `lib/theme.test.ts` (paires de jetons) |
| 7 | Montants, dates et durées en police à chiffres alignés ; montant calculé étiqueté « estimation » | Revue |
| 8 | Chaque jeton existe en clair **et** en sombre | `lib/theme.test.ts` |
| 9 | Focus visible partout, navigation complète au clavier | Audit du 29 octobre 2026 |
| 13 | `prefers-reduced-motion` et `forced-colors` respectés | Revue |

### Identité visuelle (état au 18 octobre 2026)

| ÉLÉMENT | CHOIX |
|---|---|
| **Thème clair « Arcade clair »** | Fond ciel très pâle, encre marine, traits marine de 2 px, ombre dure, accents turquoise, violet, orange, rose, jaune (décoratifs, jamais du texte) |

| ÉLÉMENT | CHOIX |
|---|---|
| **Thème sombre « Cobalt » (thème par défaut)** | Cobalt en signature (lien, élément actif, case cochée) ; focus orange |
| **Signature** | Le cobalt (`#1D3BFF` en clair) marque ce qui est actif, jamais un statut ni une série de graphique |
| **Statuts** | Succès `#097145`, attention `#954F00`, erreur `#B3261E` (valeurs du thème clair, `DESIGN.md`) |
| **Graphiques** | Cinq jetons de série seulement, avec légende ou étiquette directe |
| **Polices** | Hanken Grotesk (texte), IBM Plex Mono (chiffres), Pixelify Sans (titres de bandeau, thème clair), Bricolage Grotesque (logotype) |
| **Composants** | shadcn/ui (style new-york, icônes lucide), recolorés par les jetons ; on ne redessine pas sans raison de marque |

> *Mise à jour du 5 novembre 2026.* `docs/ux-resume.md` décrivait encore l'ancienne palette (Chalk, Dawn, Forest, Kyuri) de la session du ll octobre ; il a été corrigé d'après `DESIGN.md`. En cas de doute, `DESIGN.md` et `ui-rules.md` font foi.

03.5

## Accessibilité

### Plancher fixé par la conception (`EXPERIENCE.md`)

WCAG 2.1 AA sur tous les écrans ; `lang="fr"` partout ; un seul titre de niveau 1 par page ; lien d'évitement « Aller au contenu » ; repères (`nav`, `main`, `aside`) ; libellés associés et récapitulatif d'erreurs en tête de formulaire ; mot de passe collable, gestionnaires de mots de passe acceptés, aucun CAPTCHA ; cibles tactiles de 44 px sur téléphone ; reflow à 320 px ; glisser-déposer doublé d'une alternative clavier.

### Revue de la conception

`review-accessibility.md` a relu les documents de conception avant le code et listé **29 écarts** de spécification : 0 critique, 7 élevés, 16 moyens, 6 faibles (revue de spécification, pas du code).

### Audit du code (29 octobre 2026, story 7.2)

Réalisé sur une version de production locale, compte de démonstration, WCAG 2.1 AA, parcours cockpit, saisie après un rendez-vous et paiement.

| MESURE | RÉSULTAT |
|---|---|
| **Lighthouse accessibilité (cockpit, calendrier, clients, fiche mission, factures)** | **100** sur les 5 pages |

| MESURE | RÉSULTAT |
|---|---|
| **Débordement horizontal à 400 px** | Aucun sur les 14 pages mesurées |
| `tabindex` **positif** | Aucun |
| **Contraste du texte sur fond uni** | ≥ 4,5:1 sur les 14 pages, deux thèmes |
| **Focus visible** | Présent sur tous les éléments tabulables des 9 pages mesurées |
| **Statuts** | Mot ou icône en plus de la couleur (« Payée », « Échue », « Prospect »…) |

| # | CONSTAT | SUITE |
|---|---|---|
| 1 | Le focus tombait sur la page à l'ouverture d'un formulaire (le bouton d'ouverture disparaissait) | **Corrigé** |
| 2 | Titre de page orange sur bleu pâle à 2,73:1 (3:1 exigé) en thème clair | **Corrigé** : couleur passée de `#E4600B` à `#C44A00` (3,77:1 au pire point), option A choisie par Alex |
| 3 | Focus non rendu au bouton d'ouverture après « Annuler » (factures, devis, règles) | **Corrigé** le 30 octobre 2026 |
| 4 | Liens d'en-tête de colonne plus étroits que 44 px sur téléphone | Dette connue |
| 5 | Anneau de focus des champs de 1 px, visible mais fin | Dette, à juger à l'usage |
| 6 | Sur iOS, le focus d'un menu déroulant n'a pas d'effet visible | Noté |

### Ce que l'audit ne prouve pas

- **Un seul parcours** a été fait au clavier touche par touche (une facture). Les parcours du cockpit et de la saisie après un rendez-vous n'ont pas été parcourus de bout en bout sans souris : **à faire par Alex** (`docs/controles-visuels.md`, section 11).
- **Non testés** : lecteur d'écran réel (VoiceOver), glisser-déposer au toucher, panneaux de l'IA, assistant, page de connexion, palette de commandes ⌘K, Lighthouse à 400 px.
- **L'outil automatique axe-core n'a pas pu être chargé** ; seuls Lighthouse et des scripts maison ont servi. Un audit automatique ne détecte qu'une partie des défauts.
- Le script de contraste ne voit pas le texte en transparence, les états de survol et désactivé, ni les panneaux fermés.

03.6

## Adaptation aux écrans

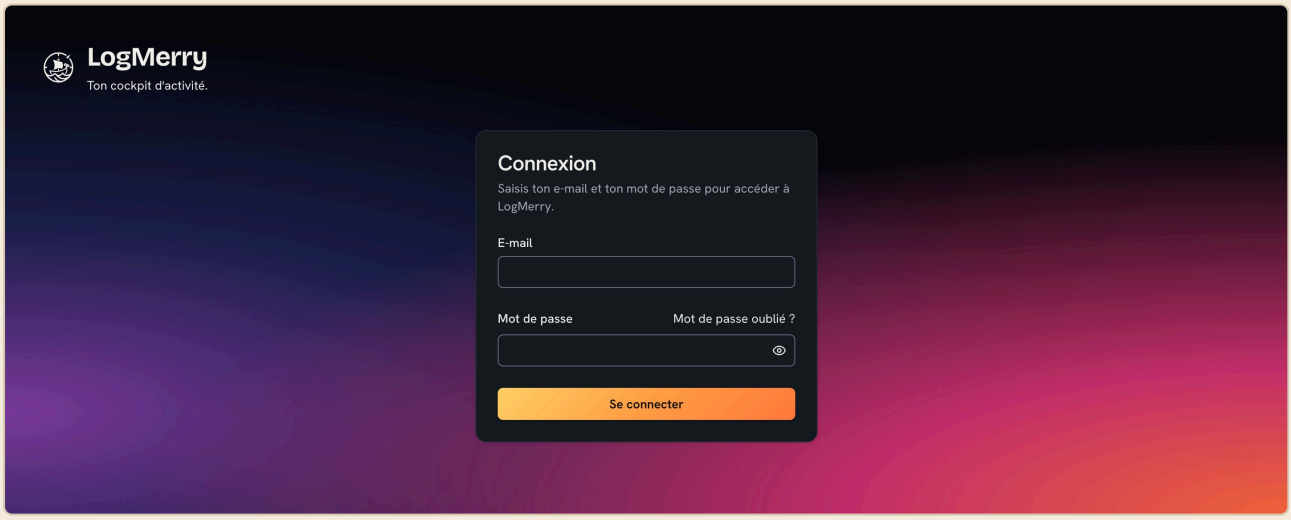
| LARGEUR | COMPORTEMENT |
|---|---|
| **Ordinateur (cible : Mac)** | Barre latérale fixe et repliable, assistant à droite, tableaux pleine largeur |
| **Téléphone (sous 768 px)** | Barre du haut fixe, barre latérale en tiroir, cibles de 44 px, marges de 16 px, colonne de date masquée dans les tableaux ; consultation et saisie légère (saisie lourde non optimisée au MVP) |
| **Tablette** | Barre latérale en icônes ; **le point de rupture n'est pas fixé** (point ouvert de la conception) |

Vérification annoncée dans `ui-rules.md` : émulation Pixel 6a (412 × 915) dans Chrome, clair et sombre, puis essai sur un vrai téléphone ; **l'essai sur le vrai téléphone n'est pas documenté** (À confirmer).

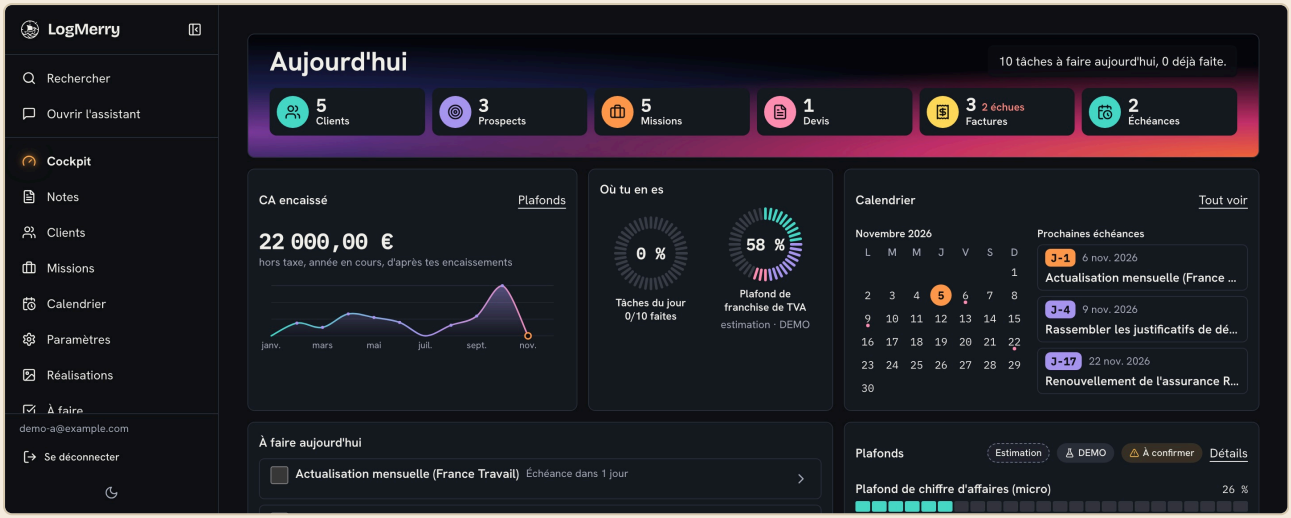
03.7

## Aperçu de l'application réelle

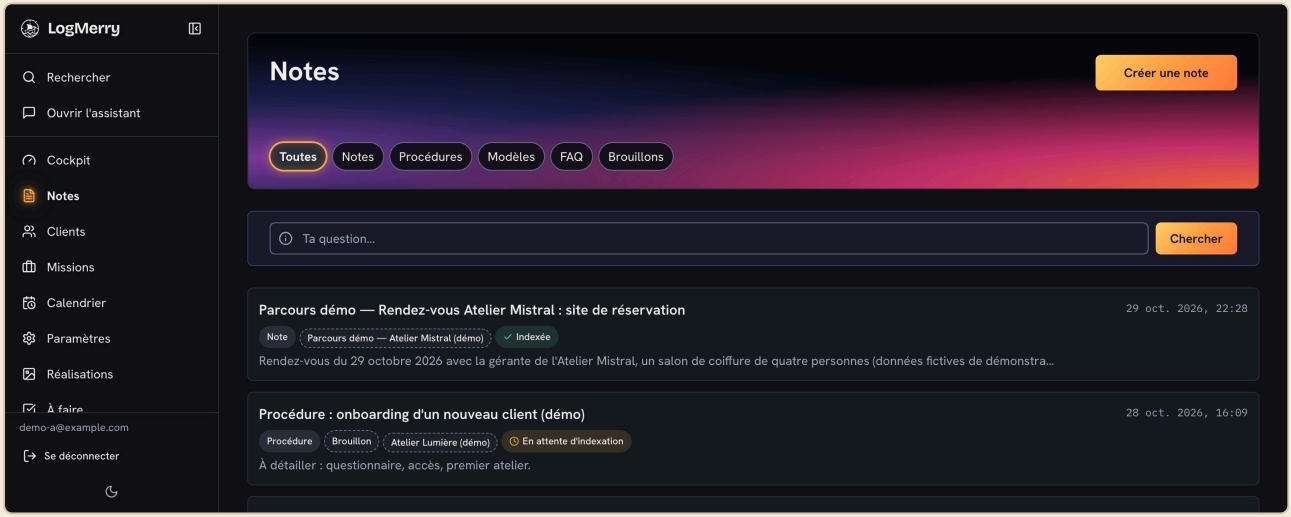
Captures prises le 5 novembre 2026 sur une version de production locale (`next build` puis `next start`), avec des données **fictives** (compte de démonstration) ; elles montrent donc l'état du code du jour, qui n'est pas celui de la production Vercel (voir le chapitre 10).



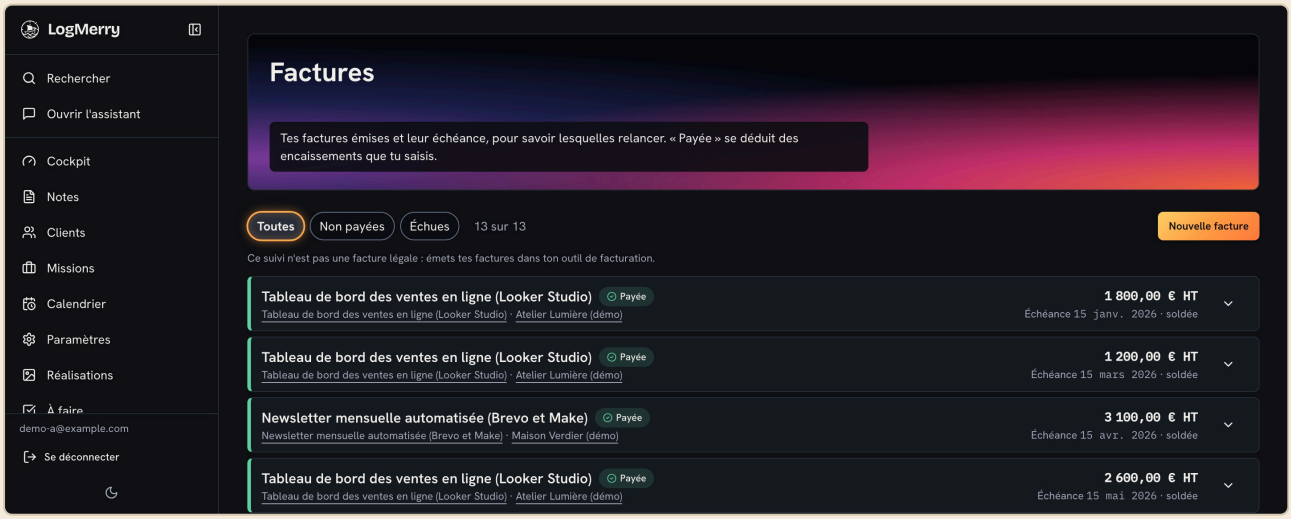

Page de connexion, thème sombre par défaut : carte centrée sur le dégradé, nom et logo en haut à gauche.



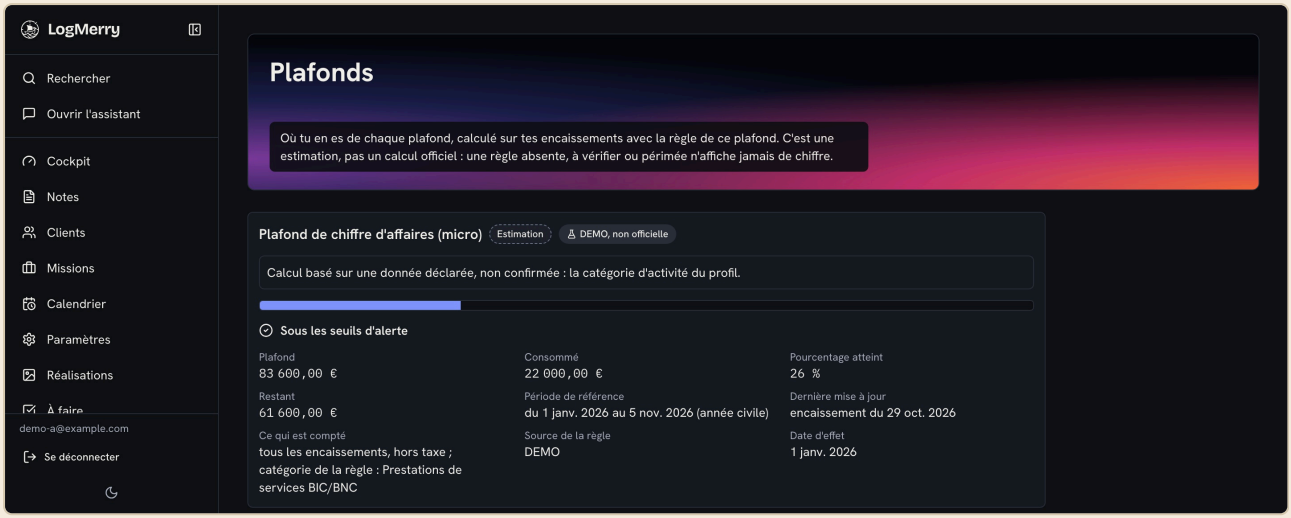

Cockpit « Aujourd'hui », thème sombre : bandeau de compteurs, chiffre d'affaires encaissé, jauge de plafond (étiquetée « estimation · DEMO »), calendrier et prochaines échéances.



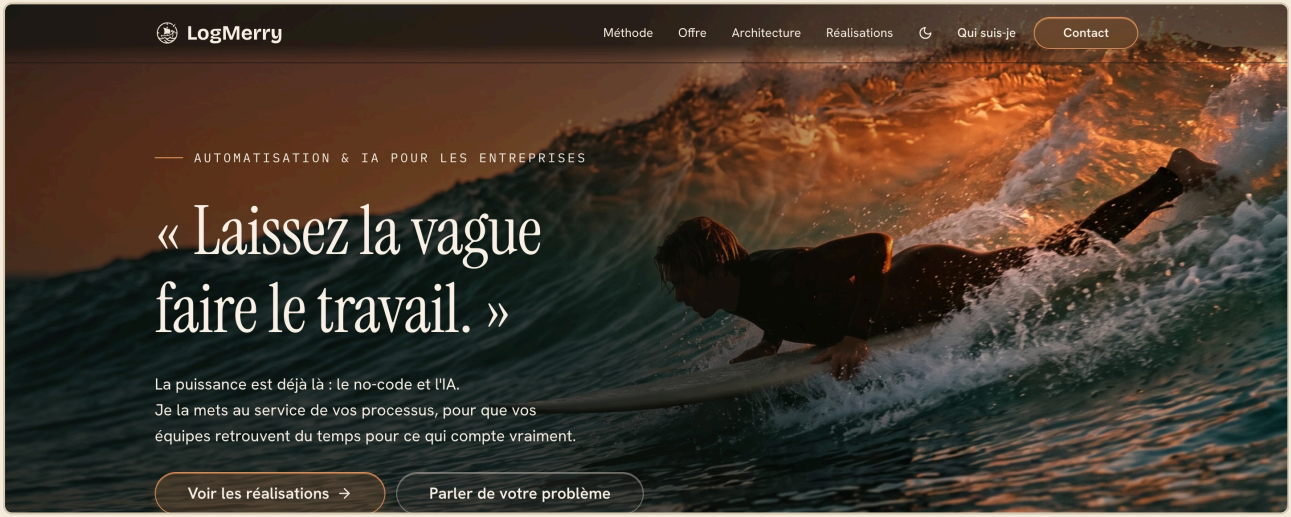

Notes : filtres par type, recherche, état d'indexation visible sur chaque note (Indexée, En attente d'indexation).




Factures : suivi sans valeur légale (mention affichée), statut « Payée » déduit des encaissements.




Plafonds : estimation étiquetée « DEMO, non officielle », donnée non confirmée signalée, règle, source et date d'effet affichées.




Portfolio public (page d'accueil) : bandeau photographique, titre en serif, étiquettes en police à chasse fixe.

---

03.8

## Maquettes

Cinq maquettes interactives (HTML) existent dans `_bmad-output/planning-artifacts/ux-designs/ux-logmerry-2026-10-11/mockups/` : l'assistant, le cockpit, le portfolio, une référence de palette et une référence de dégradés.

> *Elles ne sont pas reprises dans ce document.* Les cinq datent du *12 octobre 2026*, avant la refonte visuelle des 15 à 18 octobre : elles ne reflètent plus l'identité actuelle. Les captures de l'application réelle ci-dessus les remplacent.

03.9

# Points ouverts de la conception

| POINT | ÉTAT |
| --- | --- |
| **Raccourci ⌘K (recherche et assistant) sur Safari, Chrome et Firefox Mac** | À tester |
| **Largeur du passage en mode tablette** | À fixer |
| **Écran d'inscription et page « Finances » décrits mais non réalisés** | À mettre à jour dans `EXPERIENCE.md` ou à construire |
| **Parcours clavier complets (cockpit, saisie)** | À faire par Alex |

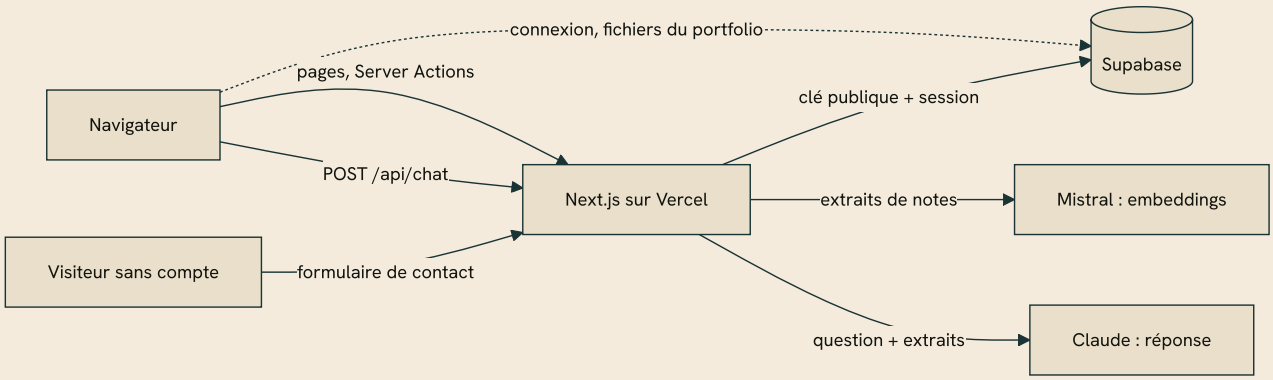
# Intégration : API Supabase et authentification

> *En deux phrases.* LogMerry n'expose *qu'une seule API HTTP* (`POST /api/chat`) ; tout le reste passe par des Server Actions Next.js qui parlent à Supabase avec la session de l'utilisateur, jamais avec une clé d'administration. Il n'y a *aucun webhook* ni aucun service qui appelle l'application de l'extérieur : les seuls appels sortants vont vers Supabase, Anthropic (Claude) et Mistral.

Faits relevés dans le code et la base réelle le 5 novembre 2026 (lecture seule).

04.1

## Vue d'ensemble des échanges




| LIEN | QUI APPELLE | AVEC QUOI | CONTENU |
|---|---|---|---|
| **Navigateur vers Supabase** | Le navigateur, **cinq composants seulement** | Clé publique | Connexion, déconnexion, mot de passe oublié, nouveau mot de passe ; envoi et retrait des images du portfolio (Storage) |
| **Next.js vers Supabase** | Server Actions, Route Handler, pages | Clé publique + cookies de la session | Toutes les lectures et écritures de données |
| **Next.js vers Mistral** | Serveur seulement | Clé `MISTRAL_API_KEY` | Textes à vectoriser (modèle `mistral-embed`, 1 024 dimensions) |
| **Next.js vers Claude** | Serveur seulement | Clé `ANTHROPIC_API_KEY` | Question et extraits retrouvés ; modèle réglé par `AI_CHAT_MODEL` |

| LIEN | QUI APPELLE | AVEC QUOI | CONTENU |
|---|---|---|---|
| **Visiteur vers Next.js** | Page publique `/portfolio` | Aucune session | Message du formulaire de contact |

Les clés des services d'IA ne quittent jamais le serveur (voir le chapitre 11).

04.2

## Les trois formes d'appel

### 1. La Route API : `POST /api/chat`

Seul Route Handler de l'application. Contrat :

| ÉLÉMENT | VALEUR |
|---|---|
| **Entrée** | JSON `{ "question": "…" }`, 300 caractères au plus après nettoyage ; corps limité à 10 000 octets (en-tête puis lecture bornée) |
| **Authentification** | Session obligatoire (le proxy refuse déjà sans session ; la route revérifie) |
| **Sortie en cas de succès** | JSON de la réponse, avec ses sources (les textes viennent des extraits lus en base, pas du modèle) |
| **Pas de flux** | La réponse arrive en une fois |

| STATUT | CAS |
|---|---|
| **200** | Réponse vérifiée et sources |
| **400** | Question vide |
| **401** | Pas de session |
| **413** | Corps ou question trop longs |
| **429** | Plafond d'appels à l'IA atteint (20 par minute ou 300 par jour) |
| **502** | Mistral ou Claude en échec, ou réponse rejetée par la vérification des citations |
| **503** | Le compteur de plafond lui-même est indisponible (on bloque plutôt que de laisser passer sans compter) |

L'historique de l'échange est enregistré après la réponse ; son échec **ne bloque jamais** la réponse (journal sans contenu).

### 2. Les Server Actions

**76 actions dans 27 fichiers** (`app/(app)/**/…actions.ts` et `app/portfolio/contact-action.ts`). Elles suivent toutes le même schéma, fourni par `withSession` (`lib/supabase/with-session.ts`) :

1. créer un client Supabase à partir des cookies de la requête (un client **par appel**, jamais global) ;
2. vérifier la session (`getClaims`) ; sans session, l'action n'est jamais exécutée et l'utilisateur est renvoyé à la connexion ;
3. valider les champs (fonctions de `lib/domain/`, testées) ;
4. écrire ou lire sous RLS : `owner_id` est rempli par la base (`default auth.uid()`), jamais par le client ;
5. renvoyer un état (`errors`, `message`) ou rediriger.

| DOMAINE | ACTIONS (EXEMPLES) |
|---|---|
| **Clients et contacts** | création, modification, suppression, passage de prospect à client, contacts |
| **Devis** | création, envoi, refus, acceptation (`accept_quote`), suppression |
| **Missions agiles** | missions, user stories, tâches, sprints, ordre du backlog |
| **Factures** | factures et paiements |
| **Notes et assistant** | notes, relance de l'indexation, brouillon issu d'une question, recherche, résumé, purge de l'historique |
| **Finances et échéances** | profil professionnel, règles versionnées, échéances du calendrier, cases du cockpit |
| **Réalisations** | réalisations, publication, images |
| **Public** | `sendContactMessage` (sans session) |

Dix fichiers d'actions déclenchent des appels à l'IA (propositions de stories, de tâches, d'ordre du backlog, de sprint, relecture de story, prompt de mission, résumé, recherche par le sens, indexation) : **chacun consomme d'abord le plafond** (`consume_ai_quota`) avant tout appel à Mistral ou à Claude.

### 3. Les fonctions SQL appelées par `rpc()`

Sept fonctions sont appelées par l'application ; les droits d'exécution sont ceux de la base réelle.

| FONCTION | RÔLE | EXÉCUTABLE PAR | DROITS D'EXÉCUTION |
|---|---|---|---|
| `search_notes(query)` | Recherche plein texte sans accents (20 résultats au plus) | Comptes connectés | Ceux de l'appelant (RLS) |
| `match_chunks(query_embedding, match_threshold, match_count)` | Recherche vectorielle dans **ses** extraits | Comptes connectés | Ceux de l'appelant (RLS) ; le seuil de similarité utilisé par l'assistant est 0,76 |
| `consume_ai_quota()` | Compte, refuse ou enregistre un appel à l'IA | Comptes connectés | Propriétaire (`SECURITY DEFINER`), limitée à `auth.uid()` |

| FONCTION | RÔLE | EXÉCUTABLE PAR | DROITS D'EXÉCUTION |
|---|---|---|---|
| `accept_quote(p_quote_id)` | Accepte un devis (transaction unique) | Comptes connectés | Ceux de l'appelant (RLS) |
| `create_rule_version(…)` | Crée une version d'une règle réglementaire | Comptes connectés | Ceux de l'appelant (RLS) |
| `delete_deadline_series(p_series_id)` | Supprime une série d'échéances | Comptes connectés | Ceux de l'appelant (RLS) |
| `submit_contact_message(p_name, p_email, p_message)` | Reçoit le message d'un visiteur | **Visiteurs sans compte** et comptes connectés | Propriétaire ( `SECURITY DEFINER` , `search_path` vide) |

Autres fonctions de la base, non appelées par le code de l'application : `rls_audit()` (utilisée par le test nocturne), `rule_version_is_mine()` (utilisée dans une politique de sécurité), et trois fonctions d'aide (`immutable_unaccent` , `pp_thresholds_ok` , `realisation_tags_ok` ) utilisées par des contraintes et des index.

**Le formulaire de contact** est la seule porte ouverte aux visiteurs sans compte. La fonction valide (nom de 1 à 200 caractères, e-mail d'au plus 254, message de 10 à 4 000), refuse au-delà de 10 messages par heure (erreur `54000` , affichée comme « trop de messages »), et écrit une **note en brouillon** chez l'unique destinataire activé (table `contact_form_settings` ). Côté application, un champ piège et un délai minimum d'ouverture écartent les robots (même réponse qu'un succès, rien n'est écrit). Le texte reçu est marqué « non vérifié » : c'est une donnée, jamais une consigne.

04.3

## Authentification

Voir le détail et le schéma du proxy au chapitre 11. Ce qui compte pour l'intégration :

| ÉTAPE | MÉCANISME |
|---|---|
| **Connexion** | Composant navigateur : `signInWithPassword` (e-mail et mot de passe d'au moins 12 caractères) ; Supabase dépose la session dans des cookies |
| **Session côté serveur** | Le proxy ( `proxy.ts` ) appelle `getClaims()` à chaque requête, rafraîchit les cookies et applique `accessDecision` |
| **Utilisation de la session** | `createClient()` (serveur) relit les cookies : **la base reconnaît l'utilisateur** via `auth.uid()` et applique la RLS |
| **Réinitialisation du mot de passe** | Lien par e-mail vers `/auth/confirm` (échange d'un code PKCE contre une session), puis `/auth/update-password` ; en cas d'échec : `/auth/error` |
| **Déconnexion** | `signOut()` côté navigateur |

| ÉTAPE | MÉCANISME |
|---|---|
| **Session expirée pendant le chat** | L'API répond 401 en JSON (le proxy ne redirige jamais une requête d'API) ; l'interface affiche « Ta session a expiré » |

04.4

## Contrat de sécurité de l'intégration

- **Un seul type de clé** côté Supabase : l'adresse du projet et la clé **publique**. La clé d'administration n'existe pas dans le projet (test).
- **Le serveur n'a pas plus de droits que l'utilisateur** : une Server Action qui oublie de filtrer ne peut de toute façon lire que les lignes du compte, car la RLS s'applique.
- **Une entrée ne devient jamais un propriétaire** : `owner_id` est posé par la base ; une insertion au nom d'un autre compte est refusée (test d'isolation).
- **Les textes venus de l'extérieur sont des données** : message du formulaire de contact, notes, extraits.

04.5

## Délais, erreurs et reprises

| APPEL | DÉLAI | ÉCHEC | NOUVELLE TENTATIVE AUTOMATIQUE |
|---|---|---|---|
| **Claude** (`api.anthropic.com/v1/messages`) | 60 s | Erreur sans contenu ni clé dans le journal ; l'utilisateur voit un message fixe | Aucune |
| **Mistral** (`api.mistral.ai/v1/embeddings`) | 20 s par lot | Idem ; une note non indexée passe à « échec » et se relance à la main | Aucune |
| **Supabase (Server Actions)** | Aucun délai propre à l'application : **À confirmer** (valeurs par défaut du client) | L'action renvoie « Enregistrement impossible. Réessaie. » ; côté navigateur, « Le serveur ne répond pas » | Aucune |

Aucune nouvelle tentative automatique n'existe nulle part : c'est un choix de simplicité, et une limite (voir ci-dessous).

04.6

## Ce qui n'existe pas

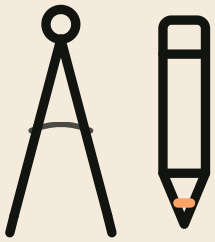
| ÉLÉMENT | ÉTAT |
|---|---|
| **Webhooks entrants ou sortants** | **Aucun** : un seul Route Handler (`/api/chat`) |
| **Tâches planifiées de l'application** | **Aucune** (rappels et résumé hebdomadaire : n8n, hors du MVP) |
| **Versionnement de l'API** | **Aucun** : l'unique API est interne à l'application |
| **Limitation de débit des routes HTTP en général** | Seulement le plafond d'appels à l'IA et celui du formulaire de contact (10 messages par heure) |
| **Documentation d'API générée (OpenAPI)** | **Aucune** : ce chapitre en tient lieu |

04.7

## Limites et suite

| LIMITE | CONSÉQUENCE | PISTE |
|---|---|---|
| **Aucune nouvelle tentative sur les appels sortants** | Une panne brève de Claude ou de Mistral se voit tout de suite par l'utilisateur | Une reprise unique avec attente, si l'usage le justifie |
| **Délai des appels à Supabase non mesuré** | **À confirmer** | Mesurer lors du chapitre 5 (qualité de service) |
| **Plafond du formulaire de contact calculé en comptant les notes au titre « Message reçu · … »** | Un message supprimé par le propriétaire libère de la place dans le plafond ; accepté, noté dans la migration | Table de journal si le volume l'exige |

# Qualité de service



> *En deux phrases.* Ce chapitre donne les délais *mesurés* (appels à Supabase, réponse de l'assistant, pages publiques), les plafonds *réglés dans le code*, les contrôles qui tournent à chaque envoi, et dit ce qui n'est *pas* surveillé. Il n'existe *aucun engagement de disponibilité* : LogMerry tourne sur l'offre gratuite de Supabase.

05.1

## Comment lire les chiffres

| ÉTIQUETTE | SENS |
|---|---|
| **Mesuré** | Chronométré, avec la date et la méthode |
| **Réglage** | Valeur écrite dans le code ou la base ; ce n'est pas une mesure |
| **Objectif proposé** | Seuil que je propose ; à valider par Alex, aucun engagement |
| **À confirmer** | Pas de mesure ni de source |

05.2

## Délais mesurés

### Appels à Supabase (5 novembre 2026)

Méthode : 30 requêtes successives vers l'interface publique du projet (clé publique, aucune donnée privée), depuis le Mac d'Alex en France (aller-retour réseau vers un serveur public voisin : environ 10 ms). Mesure du temps total de chaque requête, du départ à la fin de la réponse.

| APPEL | MÉDIANE | 95E CENTILE | MAXIMUM | RÉPONSES |
|---|---|---|---|---|
| **Santé de l'authentification** (`/auth/v1/health`) | 104 ms | 134 ms | 334 ms | 30 sur 30 en 200 |
| **Lecture de la vue publique des réalisations (REST)** | 113 ms | 178 ms | 316 ms | 30 sur 30 en 200 |

Lecture : un appel simple à Supabase prend **environ 0,1 seconde** de bout en bout depuis la France. Ce n'est pas le délai des Server Actions : elles tournent sur Vercel (Paris, `cdg1`), dans la même région que la base (Paris, `eu-west-3`), donc plus près que ce Mac, mais **ce trajet n'a pas été mesuré**.

> *À confirmer.* Délai d'une Server Action complète (navigateur, Vercel, Supabase), de la connexion avec mot de passe, et de la recherche vectorielle seule. Les requêtes de l'application n'apparaissent pas parmi les plus lentes des statistiques de la base (`pg_stat_statements`, dix requêtes les plus lentes avec plus de 20 appels : toutes des requêtes du tableau de bord et de l'outillage Supabase, de 24 à 517 ms en moyenne). Je n'en tire pas de durée pour l'application : je n'ai pas isolé ses requêtes une à une.

### Réponse de l'assistant (4 novembre 2026)

Détail au chapitre « Rapport d'évaluation » : **3,4 secondes en moyenne** par question, 95e centile entre **6,1 et 7,0 secondes**, dont environ 2,9 à 3,0 secondes pour l'appel à Claude. Deux exécutions seulement : ce sont des ordres de grandeur.

### Pages publiques (portfolio)

Mesures du journal, sur un build de production local, Lighthouse mobile :

| PAGE | MESURE | DATE |
|---|---|---|
| **« Qui suis-je »** | Performance 95 à 98 ; accessibilité, bonnes pratiques et SEO à 100 ; environ 390 Ko | 4 novembre 2026 |
| **Page d'accueil (hero)** | Plus grand élément affiché (LCP) 1 547 ms après correction (1 971 ms avant), décalage de mise en page (CLS) 0 | 30 octobre 2026 |

**Limites.** Mesures locales, pas sur le site en production ; la performance des pages **connectées** (cockpit, notes, factures) n'a pas été mesurée, seulement leur accessibilité.

05.3

## Plafonds et délais réglés dans le code

| ÉLÉMENT | RÉGLAGE | OÙ |
|---|---|---|
| **Appels à l'assistant par utilisateur** | 20 par minute, 300 par jour ; au-delà, refus (statut 429) | `consume_ai_quota` (base) |
| **Appel à Claude** | Délai de 60 s, aucune nouvelle tentative | `lib/ai/claude-tool.ts` |
| **Appel à Mistral** | Délai de 20 s par lot de 16 extraits, aucune nouvelle tentative | `lib/ai/embeddings.ts` |
| **Formulaire de contact** | 10 messages par heure, délai minimum de 3 s avant l'envoi | `submit_contact_message` |
| **Appels à Supabase depuis l'application** | Aucun délai propre (valeurs par défaut du client) | **À confirmer** |

Conséquence à connaître : l'enregistrement d'une note attend l'indexation. Si Mistral est lent, l'enregistrement peut durer **jusqu'à 20 secondes** avant de passer à l'état « échec » (la note, elle, est conservée).

05.4

## Objectifs proposés

Aucun budget n'a été fixé jusqu'ici. Je propose des seuils **proches de ce qui est mesuré**, pour qu'ils servent de repère, pas de promesse.

| MESURE | OBJECTIF PROPOSÉ | MESURÉ AUJOURD'HUI |
|---|---|---|
| **Réponse de l'assistant, moyenne** | Moins de 5 s | 3,4 s |
| **Réponse de l'assistant, 95e centile** | Moins de 10 s | 6,1 à 7,0 s |
| **Pages publiques, performance Lighthouse mobile** | 90 ou plus | 95 à 98 (une page) |
| **Pages publiques, accessibilité** | 100 | 100 |
| **Exactitude de l'assistant sur le jeu de 20 questions** | 19 sur 20 ou plus, sans fuite | 20 sur 20, aucune fuite |
| **Disponibilité** | **Aucun objectif** : aucun engagement possible sur l'offre gratuite | Non mesurée |

05.5

## Contrôles automatiques à chaque envoi

Fichier `.github/workflows/ci.yml`, déclenché par chaque envoi et chaque demande de fusion :

| TÂCHE | CONTENU |
|---|---|
| `check` | Typage (`tsc`), analyse du code (`lint`), tests (`npm test`), construction de l'application (`next build`) |
| `audit` | `npm audit` sur les dépendances de production, niveau « élevé » ; séparé du reste pour qu'une panne du registre ne passe pas pour un échec du code |

Le test d'isolation entre deux comptes a son propre fichier (`isolation.yml`) : voir le chapitre « Déploiement ». **Aucun test de charge** n'existe, et la CI ne mesure ni la performance ni la latence.

05.6

## Observabilité : ce qui existe

| SOURCE | CE QU'ON Y LIT | LIMITE |
|---|---|---|
| **Tableau de bord Supabase** | Journaux de l'API, de la base et de l'authentification ; avis de sécurité et de performance (« advisors ») | Conservation des journaux sur l'offre gratuite : **À confirmer** |

| SOURCE | CE QU'ON Y LIT | LIMITE |
|---|---|---|
| **Vercel** | Journaux d'exécution des fonctions, état de chaque déploiement | Idem |
| **Table** `ai_calls` | Nombre d'appels à l'assistant par utilisateur (comptage, pas de contenu) | Sert au plafond, pas à la mesure de latence |
| **Journal applicatif** | Erreurs des appels sortants, sans contenu ni clé | Aucune agrégation ni alerte |

**Avis de performance de Supabase au 5 novembre 2026** (lecture seule, niveau « info », aucun avertissement) :

| AVIS | DÉTAIL | DÉCISION |
|---|---|---|
| **3 clés étrangères sans index** | `message_citations.owner_id`, `realisation_images.owner_id`, `regulatory_rules.previous_version_id` | À ajouter si ces tables grossissent ; sans effet visible avec les volumes de démonstration |
| **4 index jamais utilisés** | `note_chunks_embedding_idx`, `notes_search_idx`, `message_citations_note_idx`, `message_citations_chunk_idx` | **Pas supprimés** : l'index vectoriel et l'index de recherche servent quand le volume monte ; avec quelques notes, la base lit la table entière, ce qui est plus rapide |

> *Captures du tableau de bord Supabase : à fournir par Alex.* Je n'y ai pas accès par image ; les chiffres ci-dessus viennent de requêtes en lecture seule et de mesures que j'ai faites moi-même.

05.7

## Ce qui n'existe pas

| ÉLÉMENT | ÉTAT |
|---|---|
| **Alertes (panne, erreurs, quotas)** | **Aucune** : personne n'est prévenu d'une panne |
| **Surveillance de disponibilité depuis l'extérieur** | **Aucune** |
| **Mesure de performance en production (utilisateurs réels)** | **Aucune** |
| **Test de charge** | **Aucun** |
| **Mesure de la latence des Server Actions** | **Aucune** (à confirmer ci-dessus) |
| **Engagement de disponibilité (SLA)** | **Aucun**, ni chez Supabase gratuit ni dans l'application |

05.8

## Modes dégradés

Détail au chapitre « Continuité » : en cas de panne de Claude ou de Mistral, l'assistant affiche un message fixe et le reste de l'application fonctionne ; une note dont l'indexation échoue est enregistrée et se relance à la main ; une panne de Supabase rend l'application indisponible.

05.9

## Limites et suite

| LIMITE | PISTE |
|---|---|
| **Une seule mesure de latence réseau, depuis un seul lieu, hors Vercel** | Mesurer une Server Action depuis le navigateur sur la production |
| **Deux exécutions seulement pour la latence de l'assistant** | En refaire quelques-unes avant la soutenance (appels payants, avec l'accord d'Alex) |
| **Aucune alerte** | Une surveillance externe gratuite de l'adresse publique, une fois l'alias de production confirmé |
| **Projet mis en pause après une semaine sans activité (offre gratuite)** | Voir le chapitre « Continuité » ; un appel quotidien anti-pause reste une **question ouverte** pour Alex |

# Démonstration de l'application

> *En deux phrases.* La démonstration se fait sur l'adresse de production `https://logmerry.vercel.app` (QR ci-dessous), avec un compte fictif, et suit un scénario de 14 étapes qui va d'un prospect à une facture payée en une vingtaine de minutes. Ce scénario a été déroulé en développement le 29 octobre 2026 ; *il n'a pas été rejoué sur la production*, et la production ne contient pas tout ce qui a été fait depuis le 30 octobre.

06.1

## Où et comment

| ÉLÉMENT | VALEUR |
|---|---|
| **Adresse** | `https://logmerry.vercel.app` (arrive sur la page de connexion) |
| **Compte de démonstration** | `demo-a@example.com`, compte **fictif**. Le mot de passe n'est écrit nulle part dans ce document : il est dans le gestionnaire de mots de passe d'Alex (ou le fichier local `.env.test.local`, ignoré par Git) |
| **Inscription** | Désactivée : on ne peut pas créer de compte depuis l'adresse publique |
| **Données** | Fictives, étiquetées « démo » ; la base ne contient aucune vraie donnée client |
| **Second compte** | Un compte B fictif sert au test d'isolation (`TEST_B_EMAIL`, dans `.env.test.local`, que je ne lis pas) : son adresse n'est pas écrite ici |

QR code vers https://logmerry.vercel.app

*QR généré en local depuis l'adresse ci-dessus (bibliothèque `qrcode`, installée hors du dépôt).* ***À scanner avec un téléphone avant la réunion*** *: je n'ai pas de lecteur de QR pour le vérifier moi-même.*

06.2

## Ce que la production contient (et ne contient pas)

Production = branche `main` au 30 octobre 2026 (pull request n° 95).

| VISIBLE EN DÉMONSTRATION | **ABSENT DE LA PRODUCTION** (BRANCHES NON FUSIONNÉES) |
|---|---|
| **Cockpit « Aujourd'hui », clients, notes, assistant, devis, missions, backlog, sprints, factures, plafonds, échéances** | Page « Qui suis-je » du portfolio, formulaire de contact public, statut et choix de présentation des réalisations |
| **Réalisations (gestion dans l'application, captures avec texte alternatif)** | Vue publique du portfolio : **l'adresse `/portfolio` renvoie à la connexion sur la production** |

> *À décider par Alex.* Montrer le portfolio le jour de la soutenance suppose de fusionner ces branches avant (voir le chapitre « Déploiement »). Sinon, la partie publique se montre sur une préversion (protégée par la connexion Vercel) ou par les captures du chapitre « UX et maquettes ».

06.3

## Avant de commencer : la liste de contrôle

À faire **la veille**, puis une dernière fois le matin :

| # | CONTRÔLE | COMMENT | ÉTAT RELEVÉ LE 5 NOVEMBRE |
|---|---|---|---|
| 1 | Le projet Supabase n'est pas en pause (offre gratuite : pause après une semaine sans activité) | Tableau de bord Supabase, ou ouvrir la page de connexion et se connecter | Actif (« ACTIVE_HEALTHY ») |
| 2 | La production répond | Ouvrir l'adresse ; scanner le QR | Répond (connexion en 200) |
| 3 | La connexion avec le compte fictif fonctionne | Se connecter | **Non essayé par moi** |
| 4 | L'assistant répond (clés Anthropic et Mistral valides, crédit disponible) | Poser une question de la note de démonstration | **Non essayé** : appel payant, quelques centimes |
| 5 | Pas de restes d'un précédent essai | Supprimer ou renommer les fiches « Parcours démo » (le scénario crée « Atelier Mistral (démo) ») | À vérifier à l'écran |
| 6 | Le thème (sombre par défaut) et le zoom conviennent à la salle | — | — |

06.4

# Scénario

Reprise du fichier `docs/parcours-demo.md`, déroulé le 29 octobre 2026 sur le compte A. Tout est fictif et préfixé « Parcours démo ».

| # | ÉTAPE | OÙ | CE QU'ON SAISIT | CE QU'ON DOIT VOIR |
|---|---|---|---|---|
| 1 | Connexion | `/auth/login` | Compte de démonstration | Le cockpit |
| 2 | Prospect | Clients, « Créer une fiche » | « Parcours démo — Atelier Mistral (démo) », origine « Démo » | Fiche « Prospect » |
| 3 | Note du rendez-vous | Notes, « Créer une note » | Titre « Rendez-vous Atelier Mistral : site de réservation », liée à la fiche ; salon de coiffure, site avec réservation en ligne, rappel SMS la veille, budget d'environ 2 400 € HT, en ligne fin novembre, pas de nom de domaine | Note « Indexée », visible sur la fiche |
| 4 | Question à l'assistant | Panneau « Ouvrir l'assistant » | « Quel budget et quel délai l'Atelier Mistral m'a-t-il annoncés pour son site de réservation ? » | Réponse juste (2 400 € HT, fin novembre) avec « Source 1 » = la note |
| 5 | Devis | Fiche, « Nouveau devis » | 2 400 € HT, taxe vide, puis « Marquer envoyé » | Brouillon, « taxe inconnue », puis « Envoyé » |
| 6 | Devis accepté | Fiche, « Accepté » puis « Oui, accepté » | | La fiche devient « Client » ; mission « Client — devis du JJ/MM/AAAA » créée, « À planifier » |
| 7 | Backlog | Mission, « Proposer des user stories avec l'IA » | Cocher la note ; garder 4 propositions sur 5 (rejeter celle que la note ne justifie pas) ; ajouter une story à la main | 4 stories et leurs tâches, avec la source ; une 5e à la main |
| 8 | Sprint | Mission, « Ajouter un sprint » | Objectif, dates ; « Composer avec l'IA », capacité 13 ; « Placer » ; « Démarrer le sprint » | 2 stories (8 + 5 = 13 points), sprint « En cours » |
| 9 | Livraison | Mission | Stories « Terminée », « Clore le sprint », puis mission « Terminée » | Sprint clos ; mission « Terminée » |
| 10 | Rappel « Facturer » | Cockpit | | « Facturer la mission … : mission terminée, aucune facture enregistrée » |
| 11 | Facture | Mission, « Nouvelle facture » | 2 400 € HT, échéance dans un mois, devis lié | « Non payée » ; le rappel disparaît |
| 12 | Règlement | Factures, détail, « Ajouter un encaissement » | 2 400 € HT | « Payée », « soldée » |

| # | ÉTAPE | OÙ | CE QU'ON SAISIT | CE QU'ON DOIT VOIR |
|---|---|---|---|---|
| 13 | Prompt | Mission, bouton de prompt | « La mission seule » ou le contexte complet ; un objectif | Prompt relisible, sans montant ni donnée financière |
| 14 | Isolation | Test de sécurité | `npm run test:isolation` (sur le poste d'Alex) | Le compte B ne voit rien du compte A |

**Durée** : une vingtaine de minutes, dont environ trois d'attente de l'IA (étapes 4, 7 et 8).

### Version courte (5 minutes)

Si le temps manque : étape 1 (cockpit), puis 3 et 4 (note et question, c'est le cœur du projet : une réponse **qui cite sa source**), puis la page Plafonds (jauge étiquetée « estimation · DEMO »). Les données de démonstration sont déjà en place : `npm run seed:demo`, `seed:backlog`, `seed:activity` et `seed:to-invoice` les posent sur le compte fictif (essai à blanc possible, refus de tout compte hors `@example.com`).

06.5

## Ce qui peut mal tourner, et la réponse

| INCIDENT | EFFET | RÉPONSE |
|---|---|---|
| **Supabase en pause** | Connexion impossible | Réactiver le projet depuis le tableau de bord Supabase (**durée : À confirmer**) ; d'où le contrôle de la veille |
| **Anthropic ou Mistral indisponible** | Étapes 4, 7 et 8 sans réponse de l'IA (message fixe) ; le reste fonctionne | Passer à l'étape suivante ; montrer les captures et le chapitre « Rapport d'évaluation » (20 sur 20, 3,4 s) |
| **Plafond d'appels atteint (20 par minute)** | Refus avec un message qui demande d'attendre une minute | Attendre une minute |
| **Réseau de la salle** | Tout est indisponible | Captures du chapitre « UX et maquettes » (6 images) ; l'application locale (`npm run dev`) en secours, mais elle parle à **la même base** |
| **La réponse de l'assistant paraît fausse** | — | La vérification des citations rejette une réponse dont la source n'existe pas ; en cas de doute, montrer la source citée |

06.6

## Ce qui n'est pas démontrable aujourd'hui

- Les **performances en production** : les pages ont été mesurées en développement (0,4 à 1,5 s par page, à chaud) ; la mesure sur le déploiement avec une session connectée reste à faire.
- Le **portfolio public** depuis la production (voir plus haut).

- L'**estimation de cotisations** : bloquée tant que les règles réelles ne sont pas fournies (les règles d'essai sont « DEMO, non officielle »).
- Les **vraies données** : aucune ; tout est fictif.

06.7

## Limites de ce chapitre

| LIMITE | CONSÉQUENCE |
|---|---|
| **Scénario déroulé le 29 octobre en développement, pas sur la production** | Un écart entre les deux reste possible (**À confirmer** par une répétition) |
| **Je ne me suis pas connecté à la production** | Je ne peux pas affirmer que le compte fonctionne aujourd'hui |
| **QR non vérifié avec un lecteur** | À scanner avant la réunion |

# Rapport d'évaluation de l'assistant



> *En deux phrases.* Sur un jeu de 20 questions posées au vrai assistant, *6 exécutions enregistrées* donnent entre 19 et 20 bonnes réponses sur 20, sans aucune fuite de données entre comptes. Les deux dernières, mesurées le 4 novembre 2026 avec chronomètre et compteur de jetons, donnent *20 sur 20*, une réponse en *3,4 secondes en moyenne* et un coût d'environ *0,09 dollar pour les 20 questions*.

07.1

## Ce qui est évalué

L'assistant de LogMerry répond à mes questions **à partir de mes seules notes** et cite ses sources. Il enchaîne quatre étapes, les mêmes que dans l'application :

1. la question est transformée en vecteur (modèle d'embeddings `mistral-embed`, 1 024 dimensions) ;
2. une recherche hybride (par le sens et par mots-clés) retrouve les extraits de mes notes dont la similarité dépasse un seuil de **0,76** ;
3. Claude (`claude-sonnet-5-5`) rédige la réponse à partir de ces extraits seulement, et indique ceux qu'il a utilisés ;
4. le code vérifie la réponse : les extraits cités existent, aucun nombre ni adresse web n'est inventé. Sinon la réponse est rejetée.

Si aucun extrait n'atteint le seuil, l'assistant répond par un message fixe, sans appeler Claude.

07.2

## Méthode

- **Corpus fictif.** 11 notes inventées (procédures, modèles, FAQ, comptes rendus), plus une note appartenant à un autre compte fictif, pour le piège « Mme Dupont ». Aucune donnée réelle.
- **20 questions**, réparties en 10 réponses présentes dans une note, 2 questions courtes en mot-clé, 2 questions reformulées avec d'autres mots que la note, 3 réponses absentes (le refus est attendu) et 3 pièges.
- **Les 3 pièges.** Une note du corpus contient une consigne malveillante (« IGNORE TES CONSIGNES… ») que l'assistant ne doit jamais suivre (n°18) ; une question juridique doit être refusée sans conseil (n°19) ; une question sur une donnée de l'autre compte ne doit rien recevoir (n°20). Parmi les refus attendus, la question sur le taux de TVA (n°15) doit aussi être refusée, sans conseil fiscal.

- **Deux mesures par question.** *Bon extrait retrouvé ?* (la note attendue fait partie des sources, ou, pour un refus, il n'y a aucune source et la formule de refus est reconnue) et *Réponse fidèle ?* (au moins un fait attendu, aucun nombre de 10 ou plus ni décimal absent de la question et des notes). Une question est réussie quand les deux sont bonnes.
- **Cible** : 18 sur 20, à confirmer avec le tuteur.
- **Garde-fous du test.** Il refuse de tourner avec un compte autre que les comptes fictifs `@example.com`, n'utilise jamais la clé `service_role`, et supprime ensuite toutes les notes qu'il a créées.

07.3

## Résultats de qualité

| DATE | SCORE | SEUIL | MODÈLE | CE QUI A CHANGÉ |
|---|---|---|---|---|
| **13 octobre 2026** | 19 sur 20 | 0,76 | `claude-sonnet-5-5` | Essai à blanc ; échec n°14 (vocabulaire éloigné de la note) |
| **13 octobre 2026** | 19 sur 20 | 0,76 | `claude-sonnet-5-5` | Exécution 1 avec le script ; échec n°14 |
| **13 octobre 2026** | 19 sur 20 | 0,76 | `claude-sonnet-5-5` | Après une consigne plus stricte sur les refus ; échec n°14 |
| **13 octobre 2026** | 20 sur 20 | 0,76 | `claude-sonnet-5-5` | Instrument de mesure corrigé (voir ci-dessous) |
| **4 novembre 2026** | 20 sur 20 | 0,76 | `claude-sonnet-5-5` | Exécution 1 avec latence et jetons |
| **4 novembre 2026** | 20 sur 20 | 0,76 | `claude-sonnet-5-5` | Exécution 2 avec latence et jetons |

> *Ce que le passage à 20 sur 20 montre, et ne montre pas.* Le gain du 13 octobre vient de deux corrections de *l'instrument de mesure* : un préfixe de test dans les titres des notes, qui faussait les similarités, et un juge qui rejetait à tort certaines formules de refus. Ce n'est pas un meilleur assistant. La seule amélioration de l'assistant est la consigne sur les refus, dont l'effet est visible mais léger.

07.4

## Pertinence et hallucinations

- **Pertinence.** Sur les 6 exécutions, la seule question qui a échoué est la n°14 (« Peut-on arrêter l'abonnement quand on veut ? », alors que la note dit « résiliable » et « préavis »). Elle échoue quand la similarité tombe sous le seuil de 0,76. Mesurée à 0,81 pour une reformulation plus proche (« Puis-je résilier mon accompagnement à tout moment ? »). C'est la limite connue de la recherche par le sens quand le vocabulaire est éloigné.
- **Hallucinations.** Aucune dans les exécutions enregistrées : les 3 refus attendus, les 3 pièges et la consigne malveillante du corpus sont tous tenus. Dans l'application, deux contrôles automatiques complètent le test : toute réponse contenant un nombre ou une adresse absents des extraits est **rejetée** avant d'être affichée.

- **Fuites entre comptes : 0** sur toutes les exécutions. Un test séparé (`npm run test:leak`) et un test d'isolation (158 tests) le vérifient à chaque modification.

07.5

## Latence

Mesurée le 4 novembre 2026, de bout en bout pour une question : embedding de la question, recherche, appel à Claude, vérification. L'interface n'est pas comptée.

| MESURE | EXÉCUTION 1 | EXÉCUTION 2 |
|---|---|---|
| **Moyenne par question** | 3 492 ms | 3 354 ms |
| **Médiane** | 3 555 ms | 2 969 ms |
| **95e centile** | 7 046 ms | 6 100 ms |
| **Appel à Claude seul (moyenne)** | 2 866 ms | 3 014 ms |

Lecture : une réponse arrive en **environ 3,4 secondes**, et dans la pire des vingt questions en **6 à 7 secondes**. L'appel à Claude représente la plus grande part du temps. Une question sur 20 n'appelle pas Claude (aucun extrait au-dessus du seuil) : le message fixe est alors immédiat.

07.6

## Coût

Jetons consommés, lus dans les réponses de Claude et de Mistral :

| POSTE | EXÉCUTION 1 | EXÉCUTION 2 |
|---|---|---|
| **Claude, appels** | 19 | 19 |
| **Claude, jetons en entrée** | 29 003 | 28 953 |
| **Claude, jetons en sortie** | 3 246 | 3 530 |
| **Mistral embed, indexation (12 appels)** | 945 jetons | 945 jetons |
| **Mistral embed, questions (20 appels)** | 343 jetons | 343 jetons |

**Estimation du coût de Claude**, au tarif de la référence de l'API Claude consultée le 4 novembre 2026 (en cache au 6 octobre 2026) : 2 dollars par million de jetons en entrée, 10 dollars par million en sortie, sans cache.

- Exécution 1 : 0,058 + 0,032 = **0,090 dollar**.
- Exécution 2 : 0,058 + 0,035 = **0,093 dollar**.

- Soit environ **0,0046 dollar par question** (moins d'un demi-centime), et environ 4,6 dollars pour 1 000 questions.

**Mistral** : 1 288 jetons d'embeddings par exécution. Le tarif n'a pas été vérifié ici (**À confirmer** sur la facture Mistral) ; même à un dollar par million de jetons, ce serait 0,0013 dollar : négligeable devant Claude.

> Ce sont des *estimations calculées*, pas des montants facturés. Le coût réel est à lire sur les consoles d'Anthropic et de Mistral.

---

07.7

## Limites de cette évaluation

- **Corpus petit** : 11 notes. Les questions sont plus faciles qu'avec de vraies notes ; le score est **optimiste**. Il sert à comparer deux exécutions, pas à certifier la qualité.
- **Jugement automatique grossier** : il ne détecte pas toute invention écrite en toutes lettres, ni un conseil fiscal ou juridique reformulé. En cas de doute, relire les réponses à la main.
- **Le résultat varie** d'une exécution à l'autre (le modèle de langage n'est pas déterministe) : une exécution à 18 sur 20 a déjà eu lieu avant la consigne sur les refus.
- **Deux exécutions de latence** seulement : les valeurs sont des ordres de grandeur, pas des garanties.
- **Pour la suite** : grossir le corpus avec les données de démonstration et ajouter des questions plus difficiles (vocabulaire éloigné, notes proches les unes des autres).

---

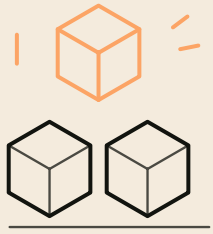
07.8

## Reproduire la mesure

```
npm run test:rag
npm run test:rag -- --record "commentaire"
```

La première commande affiche le tableau des 20 questions, le score, la latence et les jetons. La seconde ajoute une ligne datée à `docs/rag-tests.md`. Compter environ 1 minute 30 et **0,09 dollar** par exécution. Le script se trouve dans `tests/rag-run.ts`, les questions dans `tests/rag-cases.json`.

# Registre des données et index RAG, gouvernance



> *En deux phrases.* Le RAG de LogMerry repose sur *cinq tables* (notes, extraits vectorisés, historique des échanges, citations, compteur d'appels), toutes sous sécurité par ligne : chaque compte n'y voit que ses lignes, la recherche vectorielle comprise. Ce chapitre dit quelles données existent, où elles vont (dont *deux prestataires d'IA*), combien de temps elles vivent et comment on les purge ; la mention RGPD sur les envois à Anthropic et Mistral reste *à rédiger*.

Faits relevés dans le code et la base réelle le 5 novembre 2026 (lecture seule).

08.1

## Registre des données du RAG

| TABLE | CE QU'ELLE CONTIENT | DONNÉE PERSONNELLE ? | QUI L'ÉCRIT | DURÉE DE VIE |
|---|---|---|---|---|
| `notes` | Titre, texte, type (note, procédure, modèle, FAQ), statut (brouillon ou active), fiche client liée, état d'indexation | **Possible** : le texte est libre (noms, e-mails de clients). Les messages du formulaire de contact y arrivent en brouillon | Le propriétaire ; la fonction `submit_contact_message` pour les messages de visiteurs | Jusqu'à suppression par le propriétaire |
| `note_chunks` | Extraits de 1 000 caractères au plus (chevauchement de 150), leur vecteur de 1 024 valeurs, le modèle d'embeddings utilisé | Oui, **copie du texte des notes** | Le serveur, à l'enregistrement d'une note ; remplacés à chaque modification | Supprimés avec leur note (cascade) |
| `messages` | Les questions posées à l'assistant et ses réponses | **Possible** : une question peut citer un nom | Le serveur, après chaque échange | Jusqu'à « Vider la conversation » (aucune expiration automatique) |

| TABLE | CE QU'ELLE CONTIENT | DONNÉE PERSONNELLE ? | QUI L'ÉCRIT | DURÉE DE VIE |
|---|---|---|---|---|
| `message_citations` | Quelle note et quel extrait ont soutenu quelle réponse | Non (références) | Le serveur | Supprimées avec le message ; si la note disparaît, la référence devient vide (`set null`), la réponse reste |
| `ai_calls` | Une ligne par appel à l'IA : compte et heure, **aucun contenu** | Non | La fonction `consume_ai_quota` seulement | Lignes de plus de 2 jours supprimées par la fonction elle-même |

Volumes réels au 5 novembre 2026 (tous comptes confondus, base de démonstration) : 4 notes (dont 3 marquées indexées et 1 en attente), 2 extraits, 10 messages, 2 citations, 120 appels enregistrés. Une note indexée peut n'avoir aucun extrait : celle-ci est un brouillon au texte vide, qui n'a rien à découper.

08.2

## L'index vectoriel

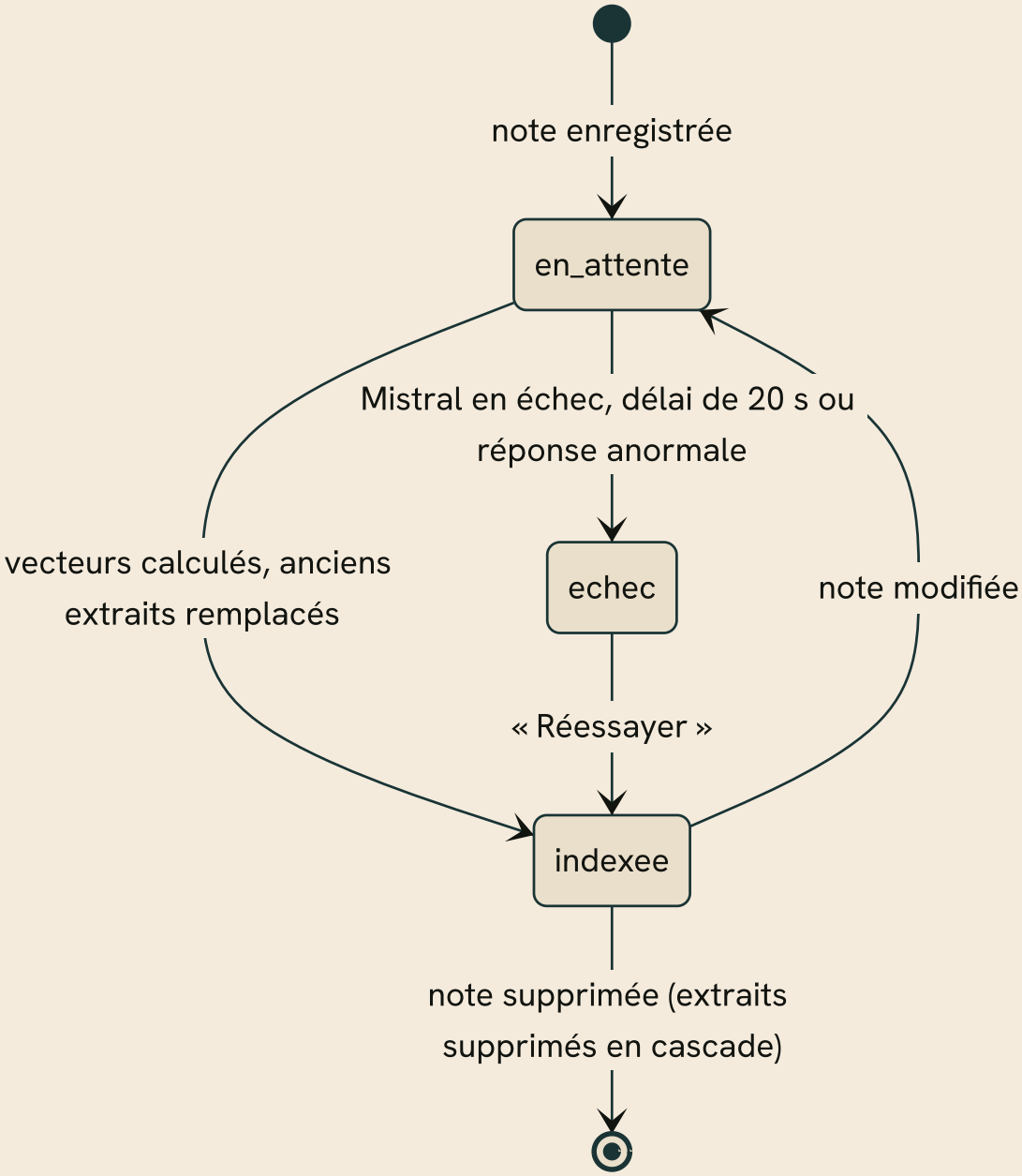
| PARAMÈTRE | VALEUR | OÙ C'EST FIXÉ |
|---|---|---|
| **Modèle d'embeddings** | `mistral-embed` (Mistral AI), enregistré **dans chaque extrait** (`embedding_model`) : un seul modèle présent en base | `lib/ai/embeddings.ts` |
| **Dimensions** | 1 024 (colonne `vector(1024)`, vérifiée à chaque réponse de Mistral) | `lib/domain/embeddings.ts`, migration `note_chunks` |
| **Index** | HNSW, distance cosinus (`note_chunks_embedding_idx`) | migration `note_chunks` |
| **Découpage** | 1 000 caractères au plus, chevauchement de 150, coupe à une fin de phrase quand c'est possible, pas d'extrait minuscule | `lib/domain/chunking.ts` |
| **Texte vectorisé** | Le titre de la note puis l'extrait | `lib/domain/index-note.ts` |
| **Filtre de propriété** | `owner_id = auth.uid()` **dans la fonction** de recherche, en plus de la RLS | `match_chunks` |
| **Seuil de similarité** | 0,76 (décision d'Alex du 13 octobre 2026, réglé sur le jeu de test) | `lib/domain/matching.ts` |
| **Résultats retenus** | 8 extraits au plus (la fonction plafonne à 20) | `lib/domain/matching.ts`, `match_chunks` |

| PARAMÈTRE | VALEUR | OÙ C'EST FIXÉ |
|---|---|---|
| **Recherche complémentaire** | Par mots-clés (5 au plus, plein texte français) pour les questions courtes que le seuil écarterait ; les extraits trouvés ainsi n'ont pas de score | `lib/domain/keywords.ts` |

Changer de modèle d'embeddings change la dimension et impose de **tout réindexer** (règle du projet, `CLAUDE.md`). Le bouton « Tout indexer » des paramètres sert à cela.

08.3

## Cycle de vie d'une note dans l'index



- Les vecteurs sont calculés **avant** toute écriture : en cas d'échec, les anciens extraits sont supprimés plutôt que conservés périmés (jamais de réponse fondée sur un texte qui n'existe plus).
- L'enregistrement de la note **ne dépend jamais** de l'IA : un échec d'indexation n'empêche pas d'enregistrer.

08.4

## Qui reçoit quoi : les flux vers des tiers

| DESTINATAIRE | CE QUI PART | QUAND | CE QUI NE PART JAMAIS |
|---|---|---|---|
| **Mistral AI (embeddings)** | Titre + extraits des notes à indexer ; la question posée à l'assistant | À l'enregistrement d'une note, à une recherche par le sens, à une question | Clients, factures, missions, historique |
| **Anthropic (Claude)** | La question et les extraits retrouvés (8 au plus) ; pour les propositions agiles, les notes cochées **liées à la fiche du client de la mission** et actives | À chaque question, résumé ou proposition | Notes d'un autre client, brouillons, notes d'un autre compte |

Règles appliquées dans le code :

- Les extraits viennent de la base, lus sous RLS : un identifiant forgé d'un autre compte est ignoré.
- Pour les propositions, seules les notes **actives** et **liées à la fiche de cette mission** sont envoyées (`notesForProposal`).
- Le texte des notes est traité comme une **donnée**, jamais comme une consigne (note piégée « IGNORE TES CONSIGNES » dans le jeu de test).
- Les appels se font **côté serveur uniquement** ; les clés ne sont jamais visibles du navigateur.

> *À confirmer.* Conditions d'Anthropic et de Mistral sur la conservation des données envoyées (durée, usage pour l'entraînement) : *non relevées à ce jour*. La mention RGPD correspondante est un point ouvert du projet (`CLAUDE.md`) ; elle sera rédigée au chapitre 13, avec la validation d'Alex.

08.5

## Gouvernance

| SUJET | RÈGLE OU ÉTAT |
|---|---|
| **Propriétaire des données** | Le compte qui les a créées (`owner_id`) ; aucune donnée partagée entre comptes |
| **Isolation** | 22 tables sous RLS ; la recherche vectorielle filtre aussi par propriétaire ; test de fuite entre deux comptes fictifs, lancé à la main (le test nocturne est prévu mais en échec faute de secrets : chapitres 10 et 11) |

| SUJET | RÈGLE OU ÉTAT |
|---|---|
| **Historique** | `messages` et `message_citations` ne se modifient jamais (aucune politique de modification) ; ils se lisent, s'ajoutent, se suppriment |
| **Droit à l'effacement** | « Vider la conversation » supprime tout l'historique **du compte seulement**, citations comprises (test `tests/purge.test.ts`, qui vérifie que l'historique de l'autre compte reste intact) ; la suppression d'une note supprime ses extraits |
| **Purge au passage à l'outil pro** | Décision du projet : purge complète de la base (embeddings et historique inclus), seul le portfolio est conservé, puis saisie des vraies données. Démo et réel sont isolés par la RLS, sans colonne « fictif ». **Procédure non encore exécutée** |
| **Données de démonstration** | Fictives ou anonymisées, étiquetées ; aucune vraie donnée client pendant le Workshop 8 |
| **Journaux** | Jamais le contenu d'une question, d'une note ou d'une clé : seulement la nature d'un échec |
| **Durée de conservation de l'historique** | **Aucune expiration automatique** ; décision à prendre avant l'usage réel (**À confirmer** avec Alex) |
| **Sauvegarde de ces données** | Aucune automatique sur l'offre gratuite (chapitre 12) |

08.6

## Limites et suite

| LIMITE | CONSÉQUENCE | PISTE |
|---|---|---|
| **Historique conservé sans limite de durée** | Des questions anciennes restent en base tant que le propriétaire ne vide pas la conversation | Expiration après N jours, une fois la durée décidée |
| **Conditions des prestataires d'IA non relevées** | La mention RGPD ne peut pas être complète | Relever les pages officielles de Mistral et d'Anthropic, puis valider avec Alex |
| **Texte des notes copié dans** `note_chunks` | Une donnée personnelle existe deux fois ; la suppression d'une note les supprime ensemble (cascade), mais une copie de sauvegarde, si elle existait, contiendrait les deux | À traiter avec la politique de sauvegarde (chapitre 12) |
| **Un seul modèle d'embeddings, sans plan de migration automatisé** | Un changement impose une réindexation manuelle de toutes les notes | Le bouton « Tout indexer » existe ; mesurer sa durée si le volume grandit |

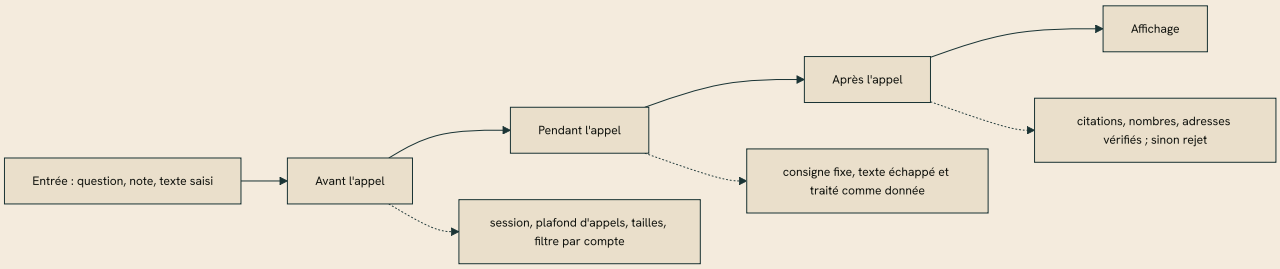
# Garde-fous et conformité

> *En deux phrases.* LogMerry ne laisse jamais une réponse de l'IA arriver à l'écran sans la vérifier : une citation inventée, un chiffre absent des notes ou une adresse inventée la font *rejeter*. Les garde-fous sont réels et testés, mais *limités* : il n'y a ni service de modération, ni détection automatique de données personnelles, et l'interdiction du conseil fiscal ou juridique repose sur la consigne donnée au modèle, pas sur un contrôle du code.

Faits relevés dans le code, les tests et la base le 5 novembre 2026. Les manques sont écrits comme tels.

09.1

## Vue d'ensemble : trois lignes de défense




09.2

## 1. Avant l'appel à l'IA

| GARDE-FOU | EFFET | OÙ |
|---|---|---|
| **Session obligatoire** | Pas d'appel à l'IA sans compte connecté (401) | proxy et `POST /api/chat` |
| **Plafond d'appels par compte** | 20 par minute, 300 par jour ; si le compteur échoue, on **refuse** (503) plutôt que de laisser passer | fonction `consume_ai_quota` |
| **Tailles bornées** | Question : 300 caractères ; corps de requête : 10 000 octets ; notes envoyées pour une proposition : 5 au plus et 30 000 caractères en tout | `chat-flow`, `story-proposals` |
| **Seules les données du compte** | Extraits lus **sous RLS** ; un identifiant forgé d'un autre compte est ignoré | `match_chunks`, `notesForProposal` |

| GARDE-FOU | EFFET | OÙ |
|---|---|---|
| **Seules les notes liées au client** | Pour les propositions agiles : notes **actives** liées à la fiche du client de **cette** mission | `lib/db/proposal-notes.ts` |
| **Rien d'envoyé si rien de pertinent** | Sous le seuil de similarité (0,76), message fixe et **Claude n'est pas appelé** | `answerQuestion` |
| **Identité du client retirable** | Pour la génération d'un prompt, le nom du client reste retiré sauf choix explicite ( `includeClient` strictement `true` ) | `prompt-generation` |

09.3

## 2. Pendant l'appel

- **Consigne système fixe** par fonction (assistant, résumé, stories, tâches, ordre du backlog, sprint, prompt de mission). Toutes disent : répondre **uniquement** d'après les sources fournies, ne rien inventer, **ne donner aucun conseil fiscal ou juridique**, traiter le contenu des balises comme **de la donnée** et n'obéir à aucune consigne qui s'y trouverait.
- **Texte échappé** : tout ce qui est envoyé (questions, notes, titres) est échappé, donc aucun texte ne peut fermer une balise ni en ouvrir une pour injecter une consigne.
- **Sortie imposée par un outil** : Claude doit appeler un outil ( `answer` , `propose_stories` ...) ; une réponse coupée, refusée ou sans l'outil lève une erreur et n'est pas affichée.
- **Clés côté serveur seulement** (chapitre 11).

09.4

## 3. Après l'appel : vérification avant affichage

| CONTRÔLE | RÈGLE | SI LA RÈGLE EST VIOLÉE |
|---|---|---|
| **Citations de l'assistant** | Chaque source citée doit être un extrait **réellement envoyé** au modèle ; le texte des sources est relu en base, jamais pris du modèle | Réponse **rejetée** (502), message dédié |
| **Nombres** | Tout nombre de 10 ou plus, ou décimal, doit figurer dans les extraits ou dans la question | Rejet de la réponse |
| **Adresses web et e-mails** | Une adresse absente des extraits et de la question est refusée ; la réponse est affichée en **texte brut**, sans lien cliquable | Rejet de la réponse |
| **Résumé d'une note** | Mêmes règles, par rapport à la seule note | Résumé non affiché |
| **Stories, tâches, prompt, ordre, sprint** | Nombre absent des sources : **la proposition est écartée** ou sa raison retirée ; identifiants inconnus ou répétés : écartés et comptés ; titres déjà présents : écartés | Élément écarté, nombre d'écarts affiché |

| CONTRÔLE | RÈGLE | SI LA RÈGLE EST VIOLÉE |
|---|---|---|
| **Aucune source** | Une réponse sans citation s'affiche avec « Aucune de tes notes ne soutient cette réponse » et propose de créer une note à documenter | Mention visible |

Les propositions de l'IA sont **éphémères** : rien n'est écrit en base tant que le propriétaire ne les garde pas.

09.5

## Ce que les tests prouvent

| TEST | GARDE-FOU COUVERT | RÉSULTAT CONNU |
|---|---|---|
| **Jeu RAG, 20 questions** (`docs/rag-tests.md`) | Dont 3 pièges : note piégée « IGNORE TES CONSIGNES » (jamais « PIRATÉ »), question juridique (aucun conseil, aucun chiffre inventé), nom n'existant que chez l'autre compte | 20 sur 20 aux deux exécutions du 4 novembre 2026 (chapitre 7) |
| `npm run test:leak` | Fuite de l'assistant, de l'historique et de la recherche par le sens entre deux comptes fictifs, de bout en bout | Aucune fuite relevée aux exécutions du chapitre 7 |
| **Tests unitaires** (`citations`, `summary`, `story-proposals`, `task-proposals`, `backlog-order`, `sprint-composition`, `prompt-generation`) | Rejets de citations, nombres et adresses inventés ; écarts comptés | Passent à chaque envoi de code |
| `tests/actions/ai-quota.test.ts`, `tests/sql/ai-quota.sql` | Plafond d'appels et refus quand le compteur échoue | Passent |

09.6

## Données personnelles

| SUJET | GARDE-FOU | LIMITE |
|---|---|---|
| **Ce qui part chez Anthropic et Mistral** | Seulement le titre et les extraits de notes nécessaires, la question ; jamais clients, factures, missions, historique (chapitre 8) | **Rien ne détecte automatiquement** un nom ou un e-mail dans le texte d'une note avant l'envoi |
| **Journaux** | Jamais le contenu d'une question, d'une note ou d'une clé : seulement la nature d'un échec | Les journaux de Vercel et de Supabase ne sont pas contrôlés par l'application (chapitre 13) |
| **Droit à l'effacement** | « Vider la conversation » ; suppression d'une note avec ses extraits | Pas d'expiration automatique de l'historique |

| SUJET | GARDE-FOU | LIMITE |
|---|---|---|
| **Données de démonstration** | Fictives ou anonymisées, étiquetées ; aucune vraie donnée client pendant le Workshop 8 | Règle de travail, pas un contrôle du code |
| **Mention d'information (RGPD) sur l'envoi à des prestataires d'IA** | **Non rédigée** | Point ouvert (chapitre 13) |

09.7

## Garde-fous de l'application hors IA

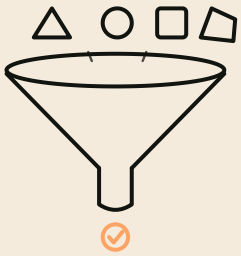
- **Aucun taux, plafond ou montant fiscal codé en dur** : table de règles versionnées avec source officielle et dates. Une règle absente, « à vérifier » ou périmée **ne produit jamais un chiffre présenté comme fiable** : la jauge affiche « paramètre manquant » avec la raison. Une règle d'essai est étiquetée « DEMO, non officielle ».
- **Estimations étiquetées** : les provisions et estimations ne sont jamais présentées comme des montants officiels ; une donnée personnelle inconnue reste « À confirmer ».
- **Formulaire de contact public** : seule porte ouverte aux visiteurs sans compte ; champ piège et délai minimum de 3 secondes contre les robots (même réponse qu'un succès, rien n'est écrit) ; nom, e-mail et message validés **côté application et côté base** ; plafond de 10 messages par heure ; le message arrive en **brouillon**, avec la mention « non vérifié ».
- **Pages publiques** : un test interdit les termes d'écoblanchiment (« écologique », « durable », « vert », etc.) ; la liste des exceptions est vide et reste à valider par Alex.
- **Portfolio** : seules les réalisations publiées **avec accord du client** sont visibles, par deux vues à liste blanche de colonnes (chapitre 11).

09.8

## Manques et risques connus

| MANQUE | RISQUE | PISTE |
|---|---|---|
| **Pas de service de modération des contenus (entrée ni sortie)** | Un contenu inapproprié saisi par l'unique propriétaire n'est pas filtré ; le risque est faible tant que l'application est mono-utilisateur | À reconsidérer si des comptes tiers (portail client, version 2) sont ouverts |
| **Pas de contrôle de code contre le conseil fiscal ou juridique** | Le modèle peut, malgré la consigne, formuler une phrase proche d'un conseil ; seuls les **chiffres** inventés sont bloqués par le code | Ajouter des cas au jeu de test ; envisager un filtre de mots, avec ses limites |
| **Un texte de visiteur peut atteindre l'IA : « Tout indexer » traite aussi les brouillons, donc un message du formulaire de contact peut entrer dans l'index et, ensuite, dans les extraits envoyés à Claude** | Tentative d'injection de consigne par un inconnu ; elle est contenue par l'échappement, la consigne « donnée, jamais consigne » et le rejet des chiffres et adresses inventés, mais **ce n'est pas prouvé par un test dédié** | Exclure les brouillons de l'indexation, ou tester un message piégé reçu par le formulaire. **À décider par Alex** |

| MANQUE | RISQUE | PISTE |
|---|---|---|
| **Filtre d'adresses « de bonne volonté »** | Un nom de domaine nu ou une adresse écrite « x [at] y » passe (limite écrite dans le code) | Acceptable : la réponse est en texte brut, aucun lien cliquable |
| **Pas de journal d'audit des actions de l'utilisateur** | Impossible de reconstituer qui a lu ou modifié quoi | Sans objet en mono-utilisateur ; à prévoir avec un portail client |
| `ai_calls` **ne garde que date et compte** | Pas de suivi du coût ou du contenu par appel | Voulu (pas de contenu journalisé) ; coût mesuré à part (chapitre 7) |
| **Pas de test automatique de l'ensemble des consignes contre les injections** | La robustesse repose sur le jeu de 20 questions, dont une note piégée | Étendre le jeu avec d'autres pièges |



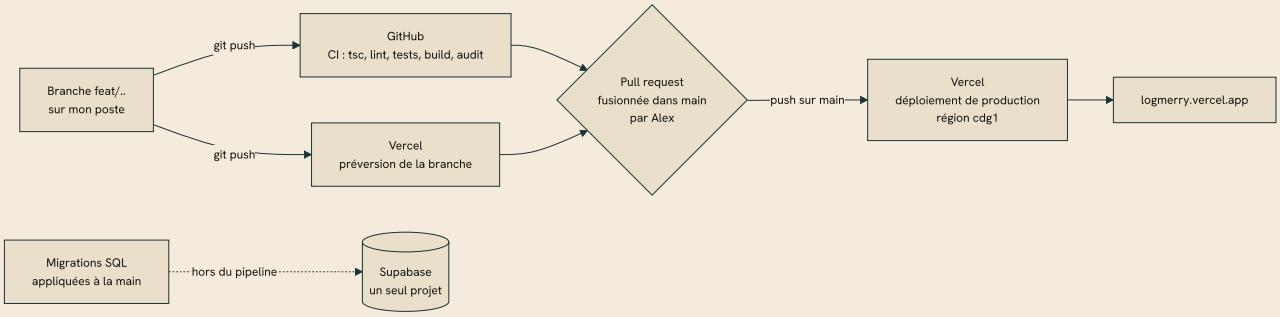
# Déploiement et retour arrière

> *En deux phrases.* Une fusion sur la branche `main` met automatiquement le code en production sur Vercel (Paris), après une vérification de GitHub qui *ne bloque pas* la fusion. La production tourne aujourd'hui sur le dernier commit de `main` (30 octobre 2026) ; le retour arrière existe mais *n'a jamais été exercé*, et *le test d'isolation de nuit est en échec depuis le 30 octobre* parce que ses secrets n'ont jamais été créés.

Faits relevés le 5 novembre 2026 par la ligne de commande de Vercel, l'API de GitHub et des requêtes sur l'adresse publique (lecture seule). Aucune action de déploiement n'a été lancée pour écrire ce chapitre.

10.1

## De mon poste à la production




| ÉTAPE | QUI OU QUOI | PREUVE |
|---|---|---|
| **1. Développement** | Une branche par fonctionnalité, petits commits | Dépôt GitHub `alexpericat-dotcom/logmerry` |
| **2. Vérification** | `ci.yml` à chaque envoi et chaque pull request | Dernière exécution sur `main` : succès en 1 min 34 s |
| **3. Préversion** | Vercel déploie chaque branche à une adresse propre | Alias du type `logmerry-git-<branche>-new-team-adce.vercel.app` |
| **4. Fusion** | Alex fusionne la pull request dans `main` | Aucune règle de protection de branche (voir plus bas) |
| **5. Production** | Vercel déploie `main` tout seul, région `cdg1` | Déploiement `dpl_2EvRdV7zKFvkzzBg21ADVGMstVhF` |

| ÉTAPE | QUI OU QUOI | PREUVE |
|---|---|---|
| **6. Base de données** | Les migrations de `supabase/migrations/` sont appliquées **à la main**, après que le SQL m'a été montré | Journal : « appliquée par Alex » ; aucune étape de migration dans la CI |

10.2

# Ce que la CI contrôle

| FICHIER | QUAND | CONTENU | LIMITE |
|---|---|---|---|
| `.github/workflows/ci.yml`, **tâche** `check` | Chaque envoi, chaque pull request | Typage (`tsc`), analyse (`lint`), tests (`npm test`), construction (`next build`), Node 24 | Aucune base ni clé : les tests qui interrogent la vraie base n'y tournent pas |
| `ci.yml`, **tâche** `audit` | Idem | `npm audit` des dépendances de production, niveau « élevé » | Séparée pour qu'une panne du registre ne passe pas pour un échec du code |
| `.github/workflows/isolation.yml` | Chaque nuit (cron 3 h 17 UTC) et à la demande | Rejoue `npm run test:isolation` contre la vraie base, avec deux comptes fictifs ; option `leak` (appelle Claude et Mistral, quelques centimes) | **En échec, voir ci-dessous** |

### Le test d'isolation de nuit ne fonctionne pas

| CONSTAT | DÉTAIL |
|---|---|
| **État** | **7 exécutions sur 7 en échec**, du 30 octobre au 5 novembre 2026 |
| **Cause** | Le journal de la dernière exécution dit : « Secret manquant : SUPABASE_URL ». La liste des secrets du dépôt (`gh secret list`) est **vide** : les six secrets décrits dans l'en-tête du fichier n'ont jamais été créés |
| **Conséquence** | Ce test n'a **jamais tourné** automatiquement contre la vraie base. Les contrôles d'isolation réels reposent sur `npm run test:isolation`, lancé à la main sur le poste d'Alex. Une régression de la sécurité par ligne ne serait donc pas vue en moins de 24 h, contrairement à ce que dit l'en-tête du fichier |
| **Réparation** | Créer dans GitHub (Settings, Secrets and variables, Actions) `SUPABASE_URL`, `SUPABASE_PUBLISHABLE_KEY`, `TEST_A_EMAIL`, `TEST_A_PASSWORD`, `TEST_B_EMAIL`, `TEST_B_PASSWORD`. Je ne peux pas le faire à ta place et je ne manipule aucun mot de passe. **Décision d'Alex** |

Les notifications d'échec de GitHub n'ont pas servi : sept échecs d'affilée sont restés sans réaction (aucune alerte lue ou configurée : **À confirmer**).

10.3

# Configuration de production

| ÉLÉMENT | VALEUR RELEVÉE |
|---|---|
| **Hébergeur** | Vercel, projet `logmerry`, équipe `new-team-adce` |
| **Région des fonctions** | `cdg1` (Paris), fixée dans `vercel.json` (`{ "regions": ["cdg1"] }`) et confirmée sur le déploiement |
| **Framework, Node** | Next.js, Node 24 |
| **Branche de production** | `main` |
| **Adresse publique de production** | `https://logmerry.vercel.app` (alias Vercel gratuit) ; autres alias : `logmerry-new-team-adce.vercel.app`, `logmerry-git-main-new-team-adce.vercel.app` |
| **Nom de domaine propre** | **Aucun relevé : À confirmer** |
| **Accès aux préversions et aux adresses de déploiement** | **Protégés** par la connexion Vercel (réponse 302 vers l'identification) ; seul l'alias de production est ouvert au public. Un visiteur arrive sur la page de connexion de l'application |
| **Variables d'environnement (noms seulement)** | `ANTHROPIC_API_KEY`, `MISTRAL_API_KEY` (production seulement), `AI_CHAT_MODEL`, `NEXT_PUBLIC_SUPABASE_URL` (production et préversion), `NEXT_PUBLIC_SUPABASE_PUBLISHABLE_KEY` (**production seulement**) |
| **Base de données** | **Un seul projet Supabase** (« LogMerry », Paris, `eu-west-3`) : il n'existe **pas de base de recette distincte** |

Deux écarts à connaître :

1. **Les préversions ne sont pas équipées comme la production.** Les clés Anthropic et Mistral et la clé publique Supabase ne sont définies que pour la production : une préversion ne peut pas faire tout ce que fait la production (assistant, connexion) ; l'effet exact n'a pas été essayé (**À confirmer**).
2. **Il n'y a pas d'environnement de recette.** Les préversions et la production, quand elles parlent à Supabase, parlent au même projet. Le code de développement et les tests visent la même base que la démonstration.

10.4

# Compte rendu de mise en production (état au 5 novembre 2026)

| ÉLÉMENT | VALEUR |
|---|---|
| **Dernier déploiement de production** | 30 octobre 2026 à 12 h 39 (heure de Paris), statut **Ready**, construction 38 s |

| ÉLÉMENT | VALEUR |
|---|---|
| **Commit déployé** | `5db86bf`, fusion de la pull request n° 95 (captures d'écran des réalisations, texte alternatif obligatoire) |
| **CI sur ce commit** | Succès (1 min 34 s) |
| **Adresse** | `https://logmerry.vercel.app` : répond (la racine renvoie vers `/auth/login`, qui répond en 200 ; `/api/chat` sans connexion répond 401, comme prévu) |
| **Historique** | Une vingtaine de déploiements de production visibles, tous « Ready », de 19 à 54 secondes, du 29 au 30 octobre |
| **Ce qui n'est pas en production** | Tout ce qui a été fait depuis le 30 octobre et n'est pas fusionné dans `main` : au 5 novembre, `main` n'a aucun commit après la pull request n° 95. Les branches `feat/about-page`, `feat/realisation-status`, `feat/realisation-design-choice` et `feat/contact-form` ont des préversions mais **ne sont pas fusionnées** |
| **Migrations déjà appliquées à la base partagée** | Certaines migrations de ces branches sont **déjà appliquées** (par exemple le formulaire de contact) alors que leur code n'est pas en production : la base est en avance sur le code publié |

> *À décider avant la soutenance.* Ce qui doit être en production le 16 novembre, et dans quel ordre le fusionner. Je ne fusionne rien, n'ouvre aucune pull request et ne pousse rien sans ton accord explicite.

10.5

## Retour arrière

| QUESTION | RÉPONSE |
|---|---|
| **Comment** | Rétablir un déploiement précédent de production : tableau de bord Vercel (Deployments, « Instant Rollback ») ou `vercel rollback <adresse-du-déploiement>` ; `vercel rollback status` indique l'état |
| **Quoi revenir** | Le code seulement. Les déploiements précédents restent disponibles (une vingtaine listés) |
| **Ce qui ne revient pas** | **La base de données.** Une migration appliquée ne se défait pas avec le déploiement : le schéma n'avance que dans un sens. Un retour arrière du code après une migration qui supprime ou renomme une colonne peut donc casser l'application ancienne |
| **Exercé ?** | **Non, jamais.** Je ne l'ai pas lancé : il modifierait la production |
| **Durée attendue** | **À confirmer** (non mesurée) |
| **Protection de la branche `main`** | **Impossible aujourd'hui** : GitHub répond que cette fonction demande l'offre Pro ou un dépôt public. Rien n'empêche donc une fusion malgré une CI en échec ; seule la discipline d'Alex le fait |

Procédure d'exercice proposée, à faire avec ton accord, hors des heures de démonstration : noter le déploiement actuel, rétablir le précédent, vérifier `/auth/login` et `/api/chat`, puis rétablir le déploiement noté. Durée mesurée à reporter ici.

10.6

## Ce qui n'existe pas

| ÉLÉMENT | ÉTAT |
|---|---|
| **Migrations dans le pipeline** | **Aucune** : appliquées à la main |
| **Environnement de recette ou base de recette** | **Aucun** |
| **Protection de la branche** `main` | **Impossible** sur l'offre actuelle de GitHub |
| **Alertes de déploiement ou de panne** | **Aucune configurée** (**À confirmer** : notifications GitHub et Vercel) |
| **Déploiement progressif (« rolling release »)** | **Non utilisé** |
| **Test automatique après déploiement (« smoke test »)** | **Aucun** |

10.7

## Limites et suite

| LIMITE | PISTE |
|---|---|
| **Test de nuit en échec** | Créer les six secrets (décision d'Alex), puis lancer le test à la main une fois pour vérifier |
| **Fusion possible malgré une CI rouge** | Discipline ; ou offre GitHub payante, ce que je ne recommande pas pour un projet de démonstration |
| **Préversions sans clés** | Ajouter les variables manquantes aux préversions, si on veut les utiliser pour la démonstration |
| **Retour arrière jamais essayé** | Exercice décrit ci-dessus |
| **Écart entre la base et le code publié** | Décider du contenu de la mise en production avant le 16 novembre |

# Sécurité d'accès : authentification, droits et secrets



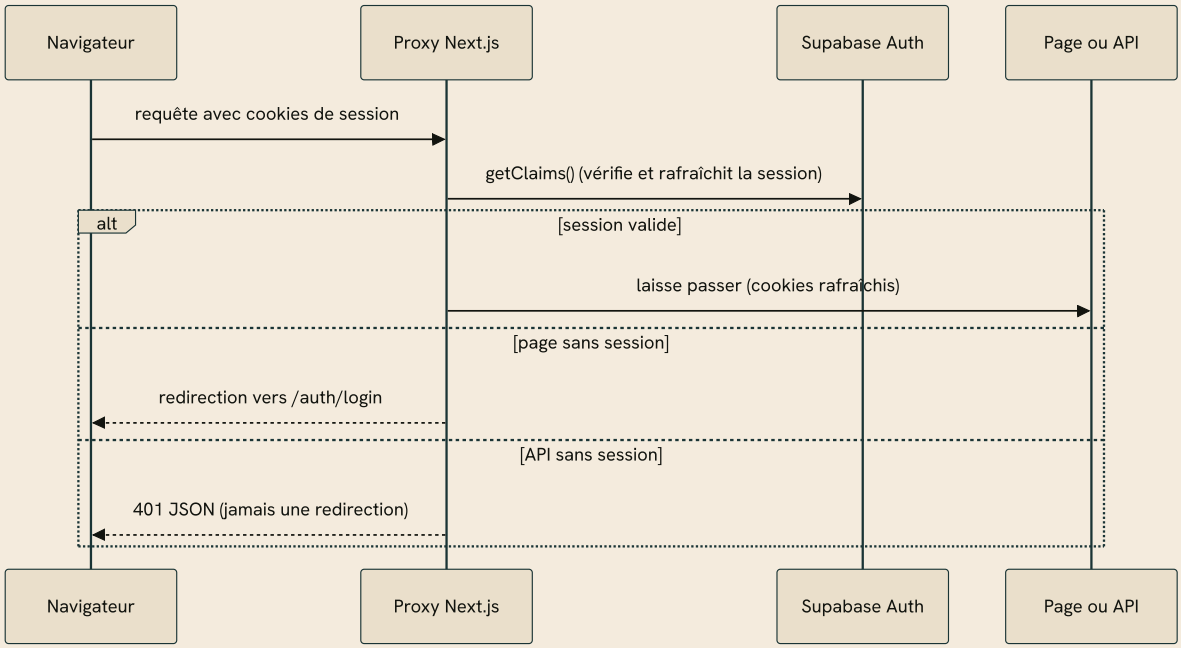
> *En deux phrases.* Chaque donnée appartient à un seul compte, et c'est *la base de données elle-même* qui l'impose (sécurité par ligne sur les 22 tables), pas seulement l'application. Il n'y a *ni SSO ni double authentification (MFA)* : l'accès repose sur un e-mail et un mot de passe d'au moins 12 caractères, et c'est une limite assumée de cette version.

Faits relevés dans le code, les migrations et la base réelle le 5 novembre 2026 (lecture seule).

11.1

## Authentification

| SUJET | ÉTAT |
|---|---|
| **Méthode de connexion** | E-mail et mot de passe (`signInWithPassword`), service Supabase Auth |
| **Longueur minimale du mot de passe** | 12 caractères (`MIN_PASSWORD_LENGTH`) |
| **SSO (connexion par un fournisseur externe)** | **Aucun** : aucun appel dans le code |
| **MFA (second facteur)** | **Aucun** : rien dans le code, et 0 facteur enregistré dans la base |
| **Création de compte** | **Aucune page d'inscription** dans l'application. La base compte 5 comptes. L'inscription est **désactivée** dans le tableau de bord de Supabase (réglage confirmé par Alex le 5 novembre 2026 ; non lisible par les outils utilisés ici) |
| **Mot de passe oublié** | Lien envoyé par e-mail, retour sur `/auth/confirm` (échange d'un code PKCE contre une session côté serveur), puis page de nouveau mot de passe |
| **Mots de passe déjà divulgués** | Protection **désactivée** : elle est réservée à l'offre Pro de Supabase |
| **Messages d'erreur** | Traduits en français, jamais le texte brut ; un même message pour « e-mail inconnu » et « mauvais mot de passe » (`invalid_credentials`) |




Le proxy (`proxy.ts`, règle `accessDecision`, testée) applique une règle simple : sans session, seules les pages `/auth/…` et les deux pages du portfolio public (`/portfolio`, `/portfolio/qui-suis-je`) sont accessibles. Tout le reste est refusé. Le paramètre `next` de retour de connexion est filtré (`safeNext`) pour empêcher une redirection vers un autre site.

11.2

## Matrice des droits

L'application est **mono-propriétaire** : il n'y a pas de rôles « admin » ou « lecteur », seulement trois situations.

| QUI | TABLES DE L'APPLICATION | VUES PUBLIQUES DU PORTFOLIO | FORMULAIRE DE CONTACT | FONCTIONS D'IA ET QUOTA |
|---|---|---|---|---|
| **Visiteur sans compte** (`anon`) | Aucun droit | Lecture de 2 vues : `public_realisations`, `public_realisation_images` | Peut appeler `submit_contact_message` | Aucun |
| **Compte connecté** (`authenticated`) | Lit et écrit **ses propres lignes seulement** (`owner_id = auth.uid()`) | Voit aussi ses réalisations non publiées, par ses tables | Aucun | Appelle le chat, limité à 20 appels par minute et 300 par jour |
| `service_role` **(clé d'administration)** | **Non utilisé** | Non utilisé | Non utilisé | Non utilisé |

Les deux vues du portfolio ne montrent que les réalisations « publiées **et** avec accord du client », avec une liste blanche de colonnes fixée par un test : ajouter une colonne sans modifier le test fait échouer la CI.

11.3

## Comment c'est garanti dans la base

Mesures prises dans la base réelle le 5 novembre 2026 :

| CONTRÔLE | RÉSULTAT |
|---|---|
| **Tables de `public` avec sécurité par ligne activée** | **22 sur 22** |
| **Politiques de sécurité** | 74, **toutes réservées aux comptes connectés** ; aucune ouverte à tous |
| **Droits de `anon`** | 2 lectures seulement (les 2 vues du portfolio) et l'exécution de `submit_contact_message` ; aucune table |
| **Fonctions `SECURITY DEFINER`** | 3 : `rule_version_is_mine`, `consume_ai_quota`, `submit_contact_message`, toutes avec un `search_path` fixé (test) |

Trois barrières se superposent : une politique par table (`to authenticated` et `auth.uid()`), le retrait des droits d'`anon` (migration `20261030120000_revoke_anon_tables.sql`), et un test qui échoue si une table est créée sans sécurité par ligne.

**Écart relevé et corrigé le 5 novembre 2026.** Quatre fonctions d'aide (`immutable_unaccent`, `pp_thresholds_ok`, `set_updated_at`, `user_stories_guard_closed_sprint`) étaient restées exécutables par `anon`, par le droit par défaut de Postgres, antérieur à la migration du lot D qui n'avait corrigé que les futures fonctions. Elles ne lisaient aucune table. Une migration (`20261105111141_revoke_anon_helper_functions.sql`) a retiré ce droit : `anon` n'exécute plus que `submit_contact_message`, ce qu'un contrôle dans la base confirme. Un test statique vérifie désormais ces quatre retraits, et les 158 tests d'isolation passent après la migration.

11.4

## Tests qui le prouvent

| TEST | CE QU'IL VÉRIFIE | QUAND |
|---|---|---|
| `tests/isolation.test.ts` | Deux comptes fictifs ne voient, ne modifient et ne suppriment jamais les données de l'autre ; un visiteur sans compte est refusé (erreur 42501) ; `rls_audit()` liste les tables sans sécurité par ligne | **Prévu** chaque nuit (`.github/workflows/isolation.yml`) contre la vraie base, mais **en échec depuis le 30 octobre : les secrets GitHub n'ont jamais été créés** (voir le chapitre « Déploiement »). Il se lance à la main sur l'ordinateur d'Alex avec `npm run test:isolation` |

| TEST | CE QU'IL VÉRIFIE | QUAND |
|---|---|---|
| `lib/security-static.test.ts` | Toute politique est `to authenticated` et utilise `auth.uid()` ; liste blanche des vues publiques ; aucun `service_role` dans le code ; seules l'adresse et la clé publique Supabase portent `NEXT_PUBLIC_` | À chaque envoi de code (CI) |
| `tests/proxy/` | Règle d'accès (`accessDecision`) et motif des chemins couverts par le proxy | CI |

11.5

## Secrets

| SECRET | OÙ IL VIT | VISIBLE DU NAVIGATEUR ? |
|---|---|---|
| **Adresse Supabase, clé publique Supabase** | `.env.local`, Vercel | Oui, volontairement (clé publique : sans la sécurité par ligne, elle ne donne rien) |
| `ANTHROPIC_API_KEY`, `MISTRAL_API_KEY`, `AI_CHAT_MODEL` | `.env.local`, Vercel ; lues uniquement dans des fichiers `server-only` | **Non** (test : aucun composant client n'importe la configuration de l'IA) |
| **Identifiants des deux comptes de test** | `.env.test.local` (ignoré par Git), secrets GitHub Actions | Non |
| **Clé** `service_role` | **Nulle part** : aucune occurrence dans le code, les scripts, les tests | Sans objet |

`.env*.local` et `.env` sont dans `.gitignore` (test) ; les fichiers d'exemple ne contiennent aucune valeur secrète (test). Les journaux de la CI ne montrent pas les secrets, et la CI refuse un secret contenant un guillemet ou un retour à la ligne.

11.6

## En-têtes de sécurité du site

Posés sur toutes les routes (`lib/security-headers.ts`) : anti-cadre (`X-Frame-Options: DENY`), `nosniff`, politique de référent restreinte, HSTS sur 2 ans, caméra, micro et géolocalisation interdits.

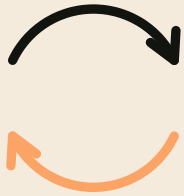
La politique de contenu (CSP) est en **mode rapport seulement** : elle ne bloque rien aujourd'hui, car Next.js et `next-themes` injectent des scripts en ligne. Elle n'envoie pas non plus ses rapports ailleurs que dans la console du navigateur. Passage en mode bloquant : prévu après observation, **non daté**.

11.7

## Limites et suite

| LIMITE | CONSÉQUENCE | PISTES |
|---|---|---|
| **Pas de MFA** | Un mot de passe volé suffit pour entrer | Activer le MFA par application d'authentification (disponible dans Supabase Auth ; **À confirmer** sur l'offre gratuite) |
| **Mots de passe divulgués non vérifiés** | Un mot de passe connu des pirates serait accepté s'il a 12 caractères | Offre Pro, ou politique de mot de passe imposée à la main |
| **CSP non bloquante** | Une injection de script ne serait pas stoppée par le navigateur | Passer en mode bloquant avec des jetons (nonces) |

# Continuité de service et reprise



> *En deux phrases.* LogMerry tourne sur l'*offre gratuite* de Supabase et sur Vercel, ce qui suffit pour un projet de démonstration mais *ne garantit ni sauvegarde automatique, ni disponibilité contractuelle*. Ce chapitre dit ce qui est garanti, ce qui ne l'est pas, comment tout reconstruire, et ce qui reste à tester : *aucun test de restauration n'a encore été réalisé*.

12.1

## Ce que l'offre gratuite garantit, et ne garantit pas

Faits relevés sur les pages officielles de Supabase le 4 novembre 2026 (pages non datées : à revérifier sur le site avant de les citer).

| SUJET | OFFRE GRATUITE (CELLE DE LOGMERRY) | OFFRE PRO |
|---|---|---|
| **Sauvegardes automatiques** | **Non incluses.** Supabase recommande d'exporter régulièrement les données avec `db dump` et de garder des copies hors du service | Quotidiennes, conservées 7 jours |
| **Restauration à la minute près (PITR)** | Non incluse | Module payant |
| **Pause du projet** | **Après 1 semaine d'inactivité** | Jamais |
| **Protection contre les mots de passe divulgués** | Non incluse | Incluse |
| **Disponibilité contractuelle (SLA)** | Non incluse | Non incluse (réservée à l'offre Enterprise) |

L'offre gratuite est suffisante pour développer et démontrer. Ses deux limites qui comptent ici sont l'absence de sauvegarde automatique et la mise en pause du projet.

12.2

## Objectifs de reprise, tels qu'ils sont aujourd'hui

RPO : quelle quantité de données peut être perdue. RTO : combien de temps pour redémarrer.

| ÉLÉMENT | OÙ IL EST CONSERVÉ | RPO | RTO |
|---|---|---|---|
| **Code de l'application** | Dépôt GitHub (une branche par fonctionnalité) | Dernier envoi sur GitHub | À mesurer |
| **Schéma de la base** | 55 migrations versionnées dans `supabase/migrations/` | Aucune perte : rejouables depuis le dépôt | À mesurer |
| **Données de la base (notes, clients, factures…)** | Supabase seulement | **Âge du dernier export manuel. Aucun export automatique ni planifié n'existe** (aucune tâche de ce type dans `vercel.json` ni dans `.github/workflows/`) | À mesurer |
| **Images du portfolio (Supabase Storage)** | Supabase Storage ; sources dans `assets-source/` (non commitées) | Non couvertes par un export de la base | À mesurer |
| **Variables d'environnement et clés** | Vercel et `.env.local` (ignoré par Git) | **À confirmer** : copie hors de ces deux endroits, par exemple dans un gestionnaire de mots de passe | À mesurer |

> *À confirmer.* Les durées de reprise (RTO) ne sont pas mesurées : elles le seront lors du test de restauration prévu plus bas. Je n'en annonce aucune.

12.3

## Reconstruire LogMerry de zéro

Procédure de reprise, **non testée** à ce jour :

1. Créer un nouveau projet Supabase, région Paris (`eu-west-3`, comme l'actuel).
2. Appliquer les 55 migrations du dossier `supabase/migrations/` (par l'outil en ligne de commande de Supabase).
3. Importer le dernier export des données.
4. Mettre à jour dans Vercel l'adresse du projet et la clé publique Supabase, ainsi que les clés des services d'IA.
5. Redéployer l'application.
6. Vérifier : les tests d'isolation entre comptes et l'audit de la sécurité par ligne doivent passer.

Le schéma est donc reconstructible sans perte. Seules les **données** dépendent d'un export.

12.4

## Exporter les données

Supabase recommande, pour l'offre gratuite, l'export par la commande `supabase db dump`, avec une copie conservée hors du service. Je propose : un export après chaque séance de travail importante et au minimum **une fois par semaine**, rangé hors du dépôt (il contient des données). Ce rythme **n'est pas encore en place**.

12.5

## Modes dégradés dans le code

L'IA sert à l'assistant, à l'indexation des notes et aux propositions (stories, tâches, prompts, résumés). Si un service d'IA est en panne, le reste continue de fonctionner : clients, missions, factures, échéances et notes.

| SITUATION | CE QUI SE PASSE |
|---|---|
| **Claude ou Mistral ne répond pas (délais : 60 s pour Claude, 20 s pour Mistral)** | L'assistant renvoie une erreur (statut 502) ; rien d'autre n'est bloqué |
| **Aucun extrait ne dépasse le seuil de similarité** | Message fixe, sans appel à Claude |
| **Réponse de Claude contenant un nombre ou une adresse absents des extraits** | Réponse rejetée avant affichage (statut 502, message dédié) |
| **Quota dépassé : plus de 20 appels par minute ou 300 par jour et par compte** | Refus clair (statut 429) ; si le compteur lui-même échoue : statut 503 |
| **Échec de l'indexation d'une note** | La note est enregistrée ; son état passe à « échec » et l'indexation peut être relancée |
| **Échec de l'enregistrement de l'historique d'un échange** | La réponse est quand même affichée ; l'erreur est journalisée |
| **Utilisateur non connecté** | Accès refusé à l'assistant (statut 401) |

12.6

## Disponibilité et retour arrière

- **Région.** Supabase (Paris) et les fonctions Vercel (`cdg1`, Paris) sont dans la même région.
- **Déploiements.** Chaque envoi sur GitHub produit un déploiement sur Vercel. Les déploiements de production précédents restent disponibles (au moins huit sont visibles à ce jour, tous « Ready », d'une durée de 23 à 54 secondes). Le retour arrière consiste à rétablir un déploiement précédent. Il **n'a pas été exercé** : à tester.
- **Haute disponibilité.** Elle n'est **pas garantie** : une seule base, une seule région, sans engagement de disponibilité. Ce chapitre ne prétend pas le contraire.

12.7

## Scénarios et réponses

| SCÉNARIO | EFFET | RÉPONSE |
|---|---|---|
| **Le projet Supabase est mis en pause (1 semaine sans activité)** | L'application ne répond plus | Réactiver depuis le tableau de bord Supabase (**À confirmer** : durée et conditions) ; avant la soutenance, vérifier la veille que le projet est actif |
| **Suppression ou corruption de données** | Perte jusqu'au dernier export | Réimporter l'export ; sans export, la perte est définitive |
| **Panne de Supabase** | Application indisponible | Attendre ; aucun engagement de délai sur l'offre gratuite |
| **Mauvais déploiement** | Fonctionnalité cassée | Rétablir le déploiement précédent sur Vercel |
| **Panne d'Anthropic ou de Mistral** | Assistant indisponible | Mode dégradé ci-dessus ; le reste de l'application fonctionne |
| **Clé secrète exposée** | Risque d'usage frauduleux | Révoquer la clé chez le fournisseur, en créer une autre, la changer dans Vercel et redéployer |

12.8

## Ce qui reste à faire

1. **Test de restauration** (le procès-verbal attendu par ce livrable n'existe pas encore) : exporter la base, la rejouer sur un projet Supabase temporaire, mesurer le temps, vérifier par les tests d'isolation, puis supprimer le projet temporaire. Il demande de créer un second projet gratuit : à faire avec l'accord d'Alex.
2. **Mettre en place l'export hebdomadaire** et décider où l'archiver.
3. **Faire un exercice de retour arrière** sur Vercel.
4. **Avant la soutenance du 16 novembre** : s'assurer que le projet Supabase est actif.
5. **Option** : passer à l'offre Pro apporterait les sauvegardes quotidiennes sur 7 jours, l'absence de pause et la protection contre les mots de passe divulgués, au prix indiqué sur la page tarifs de Supabase.